CYPROS TECHNOLOGIES PVT. LTD.
A Cert-in Empanelled Company

Chhattisgarh Medical Services Corporation Limited

Facility Module Application

Web Application Penetration Testing Report-Phase 1

Report Release Date	04 August 2026
AMBAK ID	AUD202607691841
Type of Audit	Web Application Penetration Testing Report – Phase 1
Asset URL	https://dpdmis.in/ReactFac/login
Testing Environment	Staging - Gray Box
Period	29 July 2026 to 03 August 2026
Classification	Confidential

Disclaimer: This confidential information is being provided to Chhattisgarh Medical Services Corporation Limited as a deliverable of the web application penetration testing. The purpose of this report is to provide recommendations regarding the vulnerabilities identified during the web application penetration testing. Each recipient agrees that the recipient shall not distribute or use the information contained herein and any other information regarding Cypros Technologies Private Limited for any purpose other than those stated.

Reg. Office: GR Samriddhi, No.273, 1st Floor, 7th Cross, Basavanapura Main Rd, near Silicon City College, Krishnarajapuram, Bengaluru, Karnataka – 560036.
www.cypros.in | info@cypros.in |+91 9964722968 / +91 9742353695 / +91 9538591980
GSTIN: 29AALCC5153A1ZT CIN: U69201KA2023PTC182363

Document Control

Document Details	
Document Title	Web Application Penetration Testing for Chhattisgarh Medical Services Corporation Limited- Facility Module Application
Document ID	CY-DI260804445-01
Document Version	v1.0 – Initial Report
Prepared By	Chaitrali
Reviewed By	Gnanesh G
Approved By	P Rakesh Shenoy
Released By	Nagaraja M
Release Date	04 August 2026

Document Change History		
Version	**Date**	**Remarks / Reason for change**
v1.0	04 August 2026	Initial Phase

Document Distribution List			
Name	**Organization**	**Designation**	**Email ID**
Sukhdev Kashyap	Chhattisgarh Medical Services Corporation Limited	System Manager	it.cgmsc@gov.in

Table of Contents

1. Introduction 4
2. Engagement Scope 4
3. Details of the Auditing team 4
4. Audit activities and Timelines 5
5. Audit Methodology and Criteria / Standard referred for audit 5
6. Tools and Software's used 5
7. Vulnerability Severity Legend 6
8. Executive Summary 6
8.1 Technical Details 6
8.2 Vulnerabilities distribution 10
9. Detailed Observations 12

1. Introduction

Cypros Technologies Pvt. Ltd. conducted a Web Application Penetration Testing to assess the security posture of the target web application and identify vulnerabilities that could be exploited by potential attackers. The objective of this assessment was to evaluate the effectiveness of existing security controls and provide actionable recommendations to enhance the application's overall resilience against cyber threats.

Cypros Technologies Pvt. Ltd. is empaneled by CERT-In under the Ministry of Electronics and Information Technology (MeitY), Government of India. CERT-In serves as the national nodal agency for responding to cybersecurity incidents, coordinating response measures, and strengthening the overall cybersecurity framework across India.

The assessment was conducted in accordance with globally recognized security frameworks and standards such as CERT-In guidelines, OWASP Top 10, with references to ISO/IEC 27001 and ISACA auditing guidelines. A combination of black-box and gray-box testing approaches was adopted to simulate realistic attack scenarios and ensure comprehensive vulnerability identification and validation. The results of this engagement provide valuable insights to improve application security and align it with established industry and regulatory best practices.

2. Engagement Scope

The Engagement Scope lists the applications covered, including their URLs, hash values, and versions.

SN	Asset Description	Application URL	MD5 Value	SHA Value	Application Version
1.	Web Application	https://dpdmis.in/ReactFac/login	FFFC92AA659142BCAECF17A70CABB534	09EA5A5916CD2227CFD6DDA4FF3715451364162DFE74E0446E192426CF51E6AF	1.0.0

3. Details of the Auditing team

SN	Name	Designation	Email ID	Professional Qualifications /Certifications	Whether the resource listed in the snapshot information published on CERT-In's website (Yes/No)
1.	Chaitrali	Security Engineer	Chaitrali@cypros.in	MSc, CEH	Yes

4. Audit activities and Timelines

The Web Application Penetration Testing was carried out in a phased manner to ensure comprehensive coverage and accuracy. The key audit activities and corresponding timelines are as follows:

Phase	Description	Timeline		Remarks
		From	To	
Phase-1	Initial Assessment	29 July 2026	03 August 2026	--
Phase-2	Final Assessment	--	--	--

5. Audit Methodology and Criteria / Standard referred for audit

The Web Application Penetration Testing was carried out using a combination of manual testing and automated tools, following industry best practices and standards such as the CERT-In guidelines, OWASP Top 10, and NIST SP 800-115.

- **Automated Testing**

  We used automated tools to scan the web application for known security issues. This helped quickly find possible weaknesses, wrong configurations, and outdated software components in the system.

- **Manual Testing**

  After the automated scan, we performed manual testing to check and confirm the results. Our team used their experience in web application security to find deeper issues, coding mistakes, and logic flaws that automated tools might miss.

- **Test cases and Standards**

  All test cases and attack scenarios were designed and executed mainly following the CERT-In security assessment guidelines. In addition, recognized industry standards and best practices such as OWASP Top 10, SANS 25 and NIST SP 800-15 were also referred to. This ensured a thorough and standards-based evaluation of the web application's security

6. Tools and Software's used

SN	Name of Tool / Softwares used	Version of the tool / Softwares used	Open Source / Licensed
1.	Burp Suite Professional	v.2025.1.1	Licensed
2.	Kali Linux	v.2025.3	Open Source

7. Vulnerability Severity Legend

Severity	Description
Critical	This severity level represents a critical weakness in the current control environment which could be exploited easily and requires management's immediate consideration and action to meet minimum control standards.
High	This severity level represents a significant weakness in the current control environment and requires management's immediate consideration and action to meet minimum control standards.
Medium	This level of vulnerability represents a moderate level of weakness in the current control environment and requires management action attention in the near term.
Low	This severity level provides for an opportunity to improve effectiveness and efficiency of the current control environment.
Info	This severity level represents an informational observation that is shared to provide insights or best-practice recommendations. Mitigating this issue will improve the application's overall security posture.

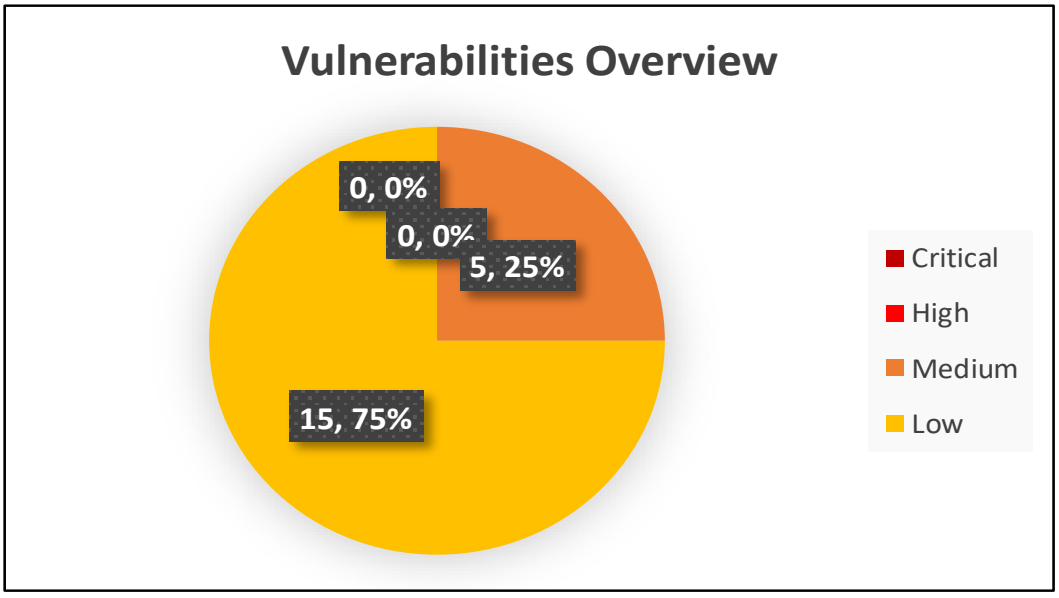
Note: Vulnerability severity is determined considering the leading security practices and past experience of Cypros assessors in executing similar projects.

8. Executive Summary

A web application penetration testing was carried out to assess the security strength of the target application against potential cyberattacks. The assessment simulated real-world attack techniques within the defined scope to identify existing threats and vulnerabilities. The objective was to evaluate the application's resilience and provide actionable recommendations to enhance its overall security posture.

A summary of vulnerabilities that have been discovered while performing web application penetration testing are given below.

Critical	High	Medium	Low	Total
0	0	5	15	20



8.1 Technical Details

SN	Vulnerability Name	Affected URL/ IP	CVE/CWE	Severity	Status
1	Cross-Origin-Resource-Sharing (CORS) misconfiguration	https://dpdmis.in/FacNodeAPI/api/auth/login/email https://dpdmis.in/FacNodeAPI/api/warehouse-receipt/fin-years	CWE-942	Medium	Open
2	Clickjacking	https://dpdmis.in/ReactFac/login	CWE-1021	Medium	Open
3	Directory listing enabled	https://dpdmis.in/bills/ https://dpdmis.in/bills/Levies/ https://dpdmis.in/bills/Levies/AdvancedLevy.aspx https://dpdmis.in/backup/04-07-19/DirectContract.aspx https://dpdmis.in/alert/ https://dpdmis.in/backup/ https://dpdmis.in/common/ https://dpdmis.in/complain/ https://dpdmis.in/complaint/ https://dpdmis.in/dashboard/ https://dpdmis.in/facility/ https://dpdmis.in/forecast/ https://dpdmis.in/index/ https://dpdmis.in/manual/ https://dpdmis.in/masters/ https://dpdmis.in/purchases/ https://dpdmis.in/receipts/ https://dpdmis.in/stock/ https://dpdmis.in/tender/ https://dpdmis.in/transfers/ https://dpdmis.in/users/ https://dpdmis.in/qa/	CWE-548	Medium	Open
4	Improper session management	https://dpdmis.in/ReactFac/masters/facility-wards https://dpdmis.in/ReactFac/dashboard	CWE-384	Medium	Open
5	Improper password policy enforcement	https://dpdmis.in/ReactFac/dashboard https://dpdmis.in/FacNodeAPI/api/auth/change-password	CWE-521	Medium	Open
6	Username and password enumeration	https://dpdmis.in/ReactFac/login	CWE-203	Low	Open
7	Server version disclosure	https://dpdmis.in/ReactFac/login	CWE-200	Low	Open

SN	Vulnerability Name	Affected URL/ IP	CVE/CWE	Severity	Status
8	Content-Security-Policy (CSP) header missing	https://dpdmis.in/ReactFac/login	CWE-693	Low	Open
9	X-Content-Type-Options header missing	https://dpdmis.in/ReactFac/login	CWE-693	Low	Open
10	Weak CBC mode ciphers	https://dpdmis.in/ReactFac/login	CWE-327	Low	Open
11	X-AspNet version disclosure	https://dpdmis.in/ReactFac/login/./../	CWE-200	Low	Open
12	Use of outdated jQuery library	https://code.jquery.com/jquery-1.11.1.min.js https://dpdmis.in/common/JQuery/JQuery.js	CWE-1104	Low	Open
13	Weak TLS ciphers	https://dpdmis.in/ReactFac/login	CWE-327	Low	Open
14	Technology version information disclosure	https://dpdmis.in/FacNodeAPI/api/auth/login/email https://dpdmis.in/FacNodeAPI/api/warehouse-receipt/fin-years	CWE-200	Low	Open
15	Cache Control header missing	https://dpdmis.in/FacNodeAPI/api/auth/login/email	CWE-525	Low	Open
16	Concurrent login	https://dpdmis.in/ReactFac/dashboard	CWE-287	Low	Open
17	Improper implementation of HTTP Strict Transport Security (HSTS) header	https://dpdmis.in/ReactFac/login	CWE-693	Low	Open
18	Improper error handling	https://dpdmis.in/https://dpdmis.in/ReactFac/login	CWE-209	Low	Open
19	Old session does not expire after password change	https://dpdmis.in/FacNodeAPI/api/auth/change-password	CWE-613	Low	Open
20	Multi-Factor Authentication (MFA) missing	https://dpdmis.in/ReactFac/login	CWE-308	Low	Open
21	HTTP OPTIONS method enabled	https://dpdmis.in/ReactFac/login	CWE-200	Info	Open

SN	Vulnerability Name	Affected URL/ IP	CVE/CWE	Severity	Status
22	Unnecessary open ports	92.4.83.38	CWE-284	Info	Open
23	Improper input validation	https://dpdmis.in/ReactFac/login https://dpdmis.in/ReactFac/masters/facility-wards https://dpdmis.in/ReactFac/masters/special-receipt-location https://dpdmis.in/ReactFac/masters/doctor-information	CWE-20	Info	Open
24	Potential buffer overflow risk	https://dpdmis.in/FacNodeAPI/api/auth/login/email	CWE-20	Info	Open

8.2 Vulnerabilities distribution

All set of applicable OWASP Top 10 Security Threats.

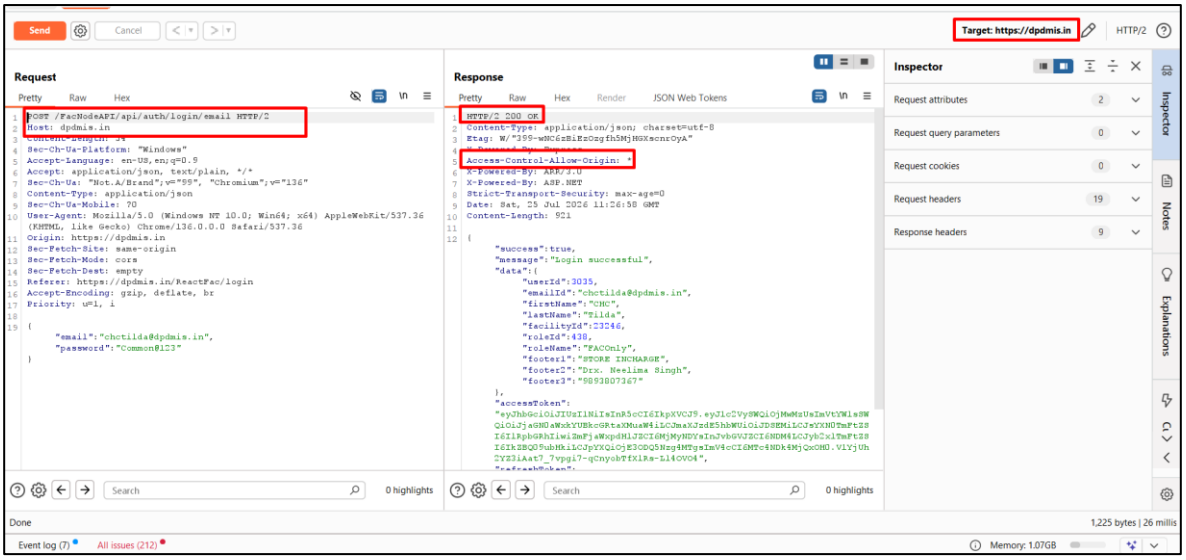
Criteria Label	Status	Vulnerability Findings
A01:2021-Broken Access Control	**Meets Criteria**	No Findings
A02:2021-Cryptographic Failures	**Fails Criteria**	• Weak CBC mode ciphers • Weak TLS Ciphers
A03:2021-Injection	**Fails Criteria**	• Improper input validation • Potential buffer overflow risk
A04:2021-Insecure Design	**Meets Criteria**	No Findings
A05:2021-Security Misconfiguration	**Fails Criteria**	• Cross-Origin Resource Sharing (CORS) misconfiguration • Clickjacking • Directory listing enabled • Server version disclosure • Content-Security-Policy (CSP) header missing • X-Content-Type-Options header missing • X-AspNet version disclosure • Technology version information disclosure • Cache-Control header missing • Improper Implementation of HTTP Strict Transport Security (HSTS) header • Improper error handling • HTTP OPTIONS method enabled • Unnecessary open ports
A06:2021-Vulnerable and Outdated Components	**Fails Criteria**	• Use of outdated jQuery library
A07:2021-Identification and Authentication Failures	**Fails Criteria**	• Improper session management • Improper password policy enforcement • Username and password enumeration • Concurrent login • Old session does not expire after password change • Multi-Factor Authentication (MFA) missing
A08:2021-Software and Data Integrity Failures	**Meets Criteria**	No Findings

Criteria Label	Status	Vulnerability Findings
A09:2021-Security Logging and Monitoring Failures	**Meets Criteria**	No Findings
A10:2021-Server-Side Request Forgery (SSRF)	**Meets Criteria**	No Findings

9. Detailed Observations

Vulnerability Point No. 1	
Affected URL/ Application/Point / Path	https://dpdmis.in/FacNodeAPI/api/auth/login/email https://dpdmis.in/FacNodeAPI/api/warehouse-receipt/fin-years
Vulnerability Name	Cross-Origin-Resource-Sharing (CORS) misconfiguration
CWE/CVE	CWE-942
Severity	**Medium**
Status	**Open**
Description	The application has an overly permissive CORS configuration that allows requests from untrusted or arbitrary origins. This can result from using wildcard origins or improper validation of the Origin header.
Impact	An attacker may exploit this issue to access sensitive data or perform unauthorized actions using a victim's authenticated session. This increases the risk of data theft and cross-site attacks.
Recommendation	CORS policies should be restricted to trusted and explicitly whitelisted domains only. Wildcard origins must be avoided, especially when credentials are enabled.
Proof of Concept	

Note: The below POC shows Cross-Origin-Resource-Sharing (CORS) misconfiguration issue.



Vulnerability Point No. 2	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login
Vulnerability Name	Clickjacking
CWE/CVE	CWE-1021
Severity	Medium
Status	Open
Description	The application does not implement clickjacking protection due to the absence of the X-Frame-Options header or equivalent controls, allowing pages to be embedded in iframe on malicious websites.
Impact	Attackers may trick users into performing unintended actions, such as submitting forms or changing settings, leading to potential compromise of user integrity and sensitive data.
Recommendation	Implement the X-Frame-Options header with DENY or SAMEORIGIN, or enforce CSP frame-ancestors, across all sensitive application pages.

Proof of Concept

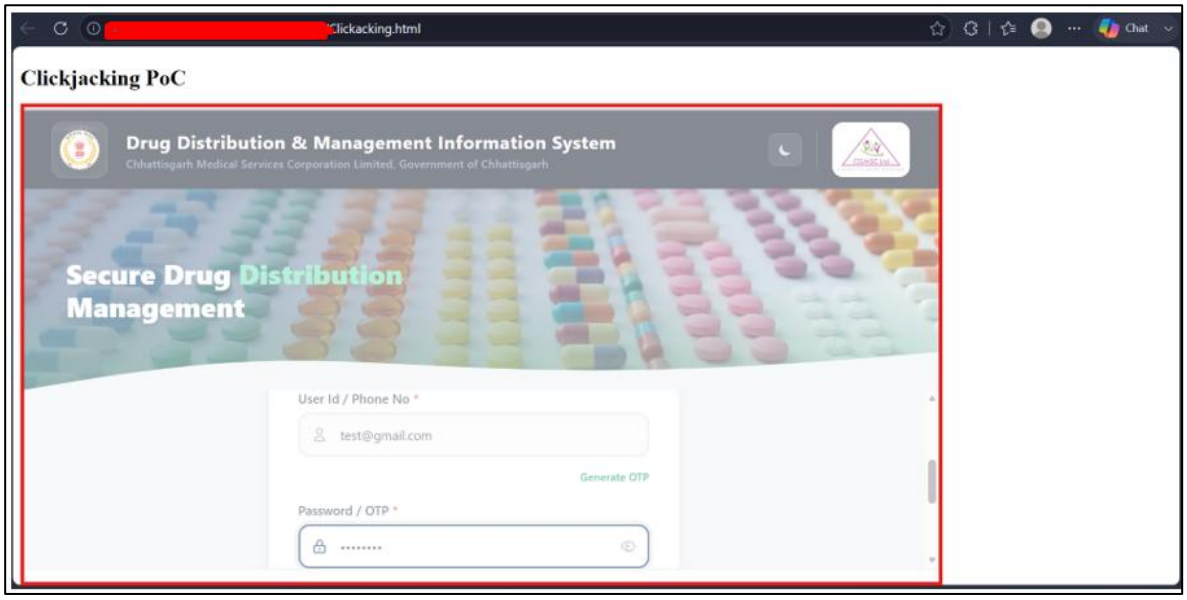
Note: The below POC shows the clickjacking issue.

```
<!DOCTYPE html>
<html>
<head>
<title>Clickjacking Test</title>
</head>
<body>
<h2>Clickjacking PoC</h2>

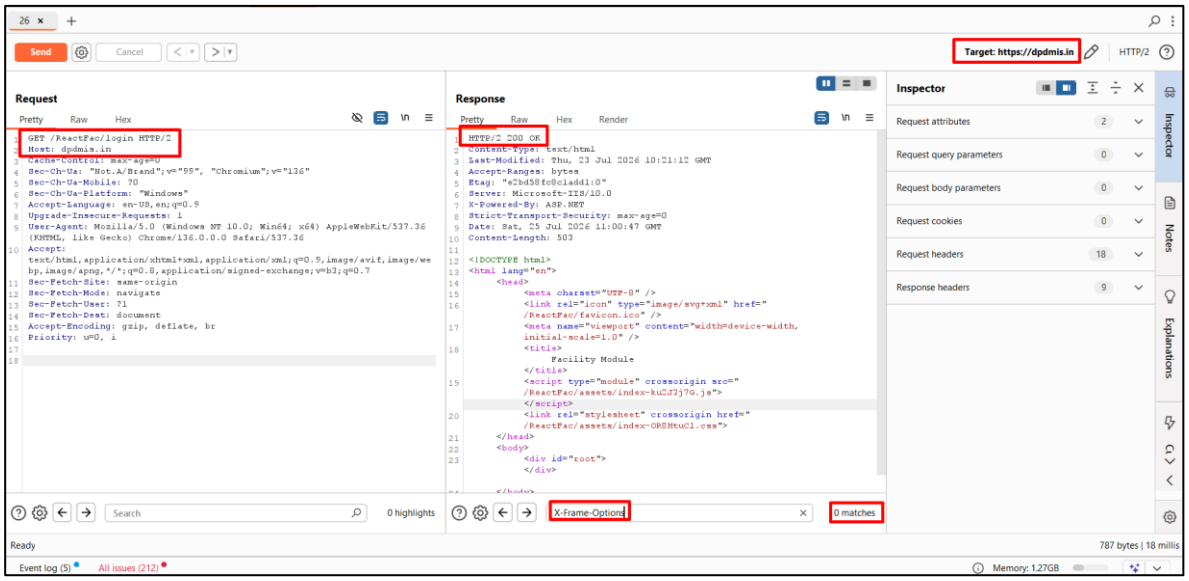
<iframe src="https://dpdmis.in/ReactFac/dashboard"
        width="1000"
        height="500"
        style="opacity:0.5;">
</iframe>

</body>
</html>
```

POC 1 – Embedded the target application (https://dpdmis.in/ReactFac/dashboard) inside an <iframe> to test for clickjacking protection.

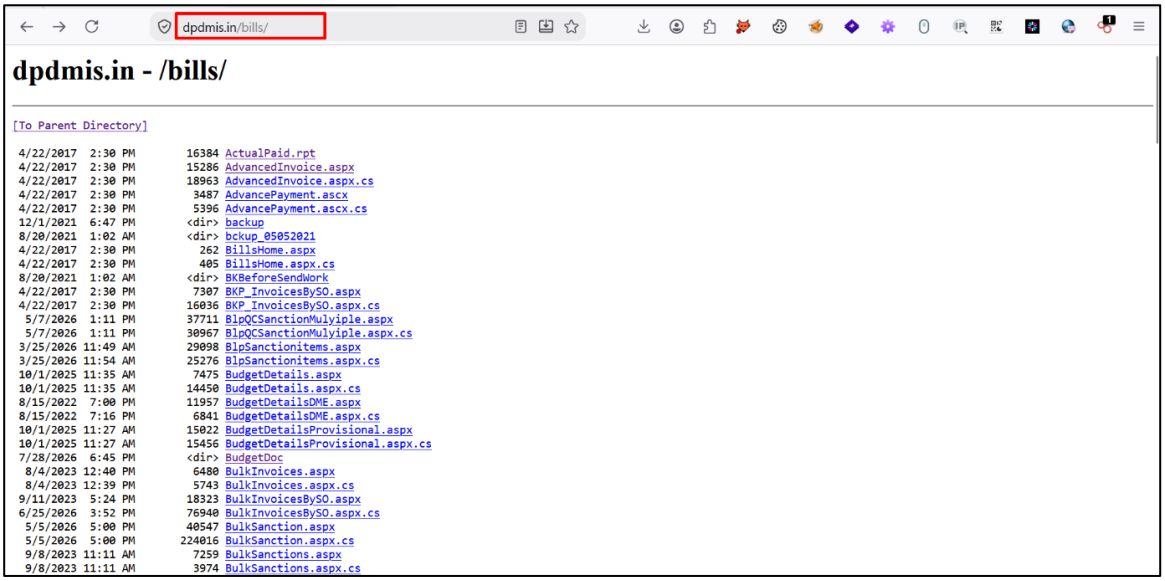


POC 2 - The application loaded successfully inside the <iframe>, demonstrating the absence of clickjacking protection.

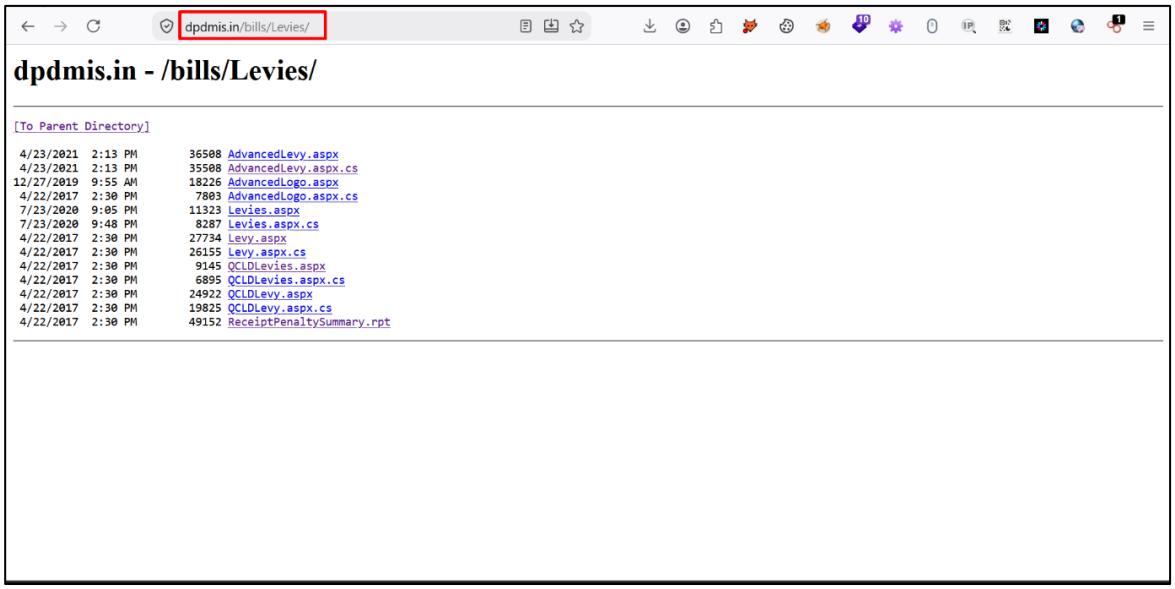


POC 3 - X-Frame-Options header is missing

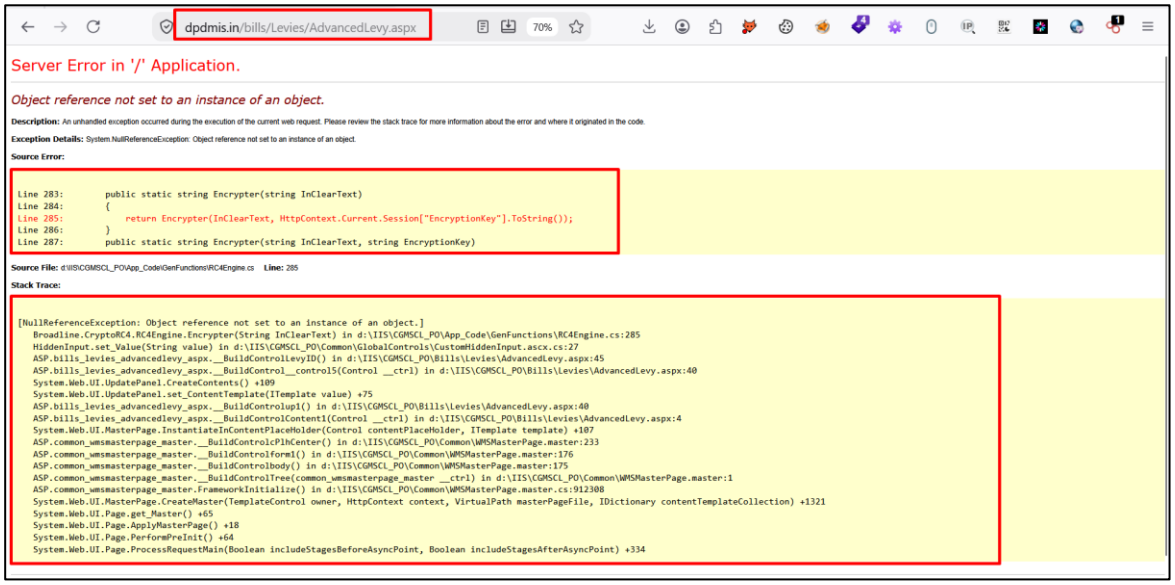
Vulnerability Point No. 3	
Affected URL/ Application/Point / Path	https://dpdmis.in/bills/ https://dpdmis.in/bills/Levies/ https://dpdmis.in/bills/Levies/AdvancedLevy.aspx https://dpdmis.in/backup/04-07-19/DirectContract.aspx https://dpdmis.in/alert/ https://dpdmis.in/backup/ https://dpdmis.in/common/ https://dpdmis.in/complain/ https://dpdmis.in/complaint/ https://dpdmis.in/dashboard/ https://dpdmis.in/facility/ https://dpdmis.in/forecast/ https://dpdmis.in/index/ https://dpdmis.in/manual/ https://dpdmis.in/masters/ https://dpdmis.in/purchases/ https://dpdmis.in/receipts/ https://dpdmis.in/stock/ https://dpdmis.in/tender/ https://dpdmis.in/transfers/ https://dpdmis.in/users/ https://dpdmis.in/qa/
Vulnerability Name	Directory listing enabled
CWE/CVE	CWE-548
Severity	**Medium**
Status	**Open**
Description	The application has directory listing enabled, allowing users to browse directory contents. While accessing certain listed directories, the application returns verbose error messages that disclose internal server paths, source code file names, class names, and line numbers, exposing sensitive implementation details.
Impact	An attacker can enumerate the application's directory structure and gather sensitive information from verbose error messages, such as internal file paths and source code details. This information can aid in reconnaissance and facilitate further attacks against the application.
Recommendation	Disable directory listing on the web server to prevent unauthorized browsing of directory contents. Configure custom error pages to suppress detailed exception messages and ensure that internal server paths, source code references, and stack traces are logged only on the server. Review directory permissions to expose only intended resources.
Proof of Concept	
Note: The below POC shows that directory listing is enabled.	



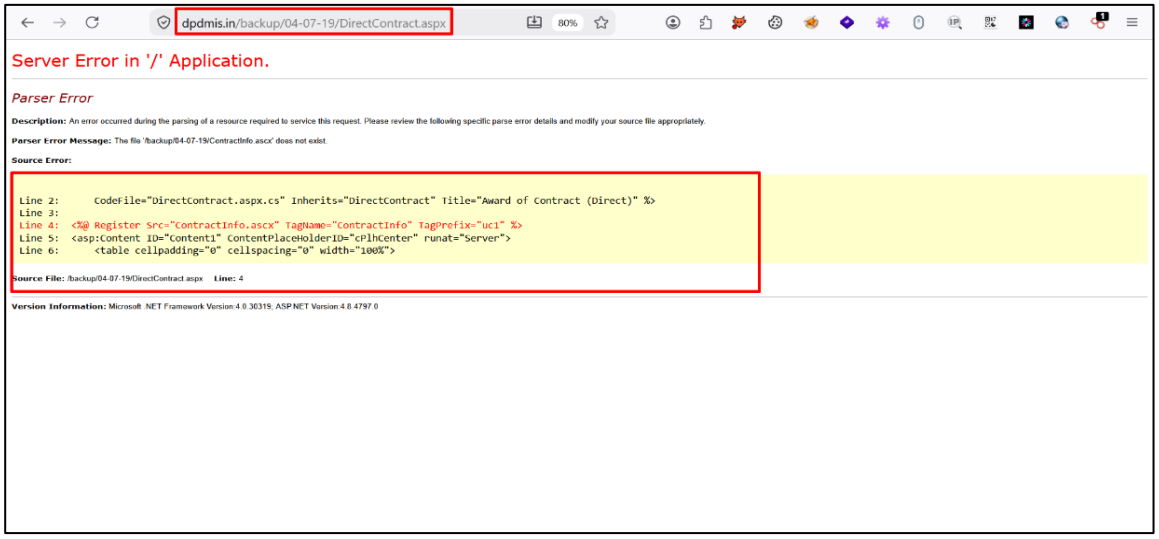
POC 1 - Accessed the target directory and observed that directory listing was enabled, exposing the available files and directories.



POC 2 - Navigated to bills → Levies and observed that the subdirectories and files were listed.



POC 3 - Navigated through bills → Levies→ AdvancedLevy.aspx, which triggered a verbose error message disclosing internal server paths, source code file names, and line numbers.

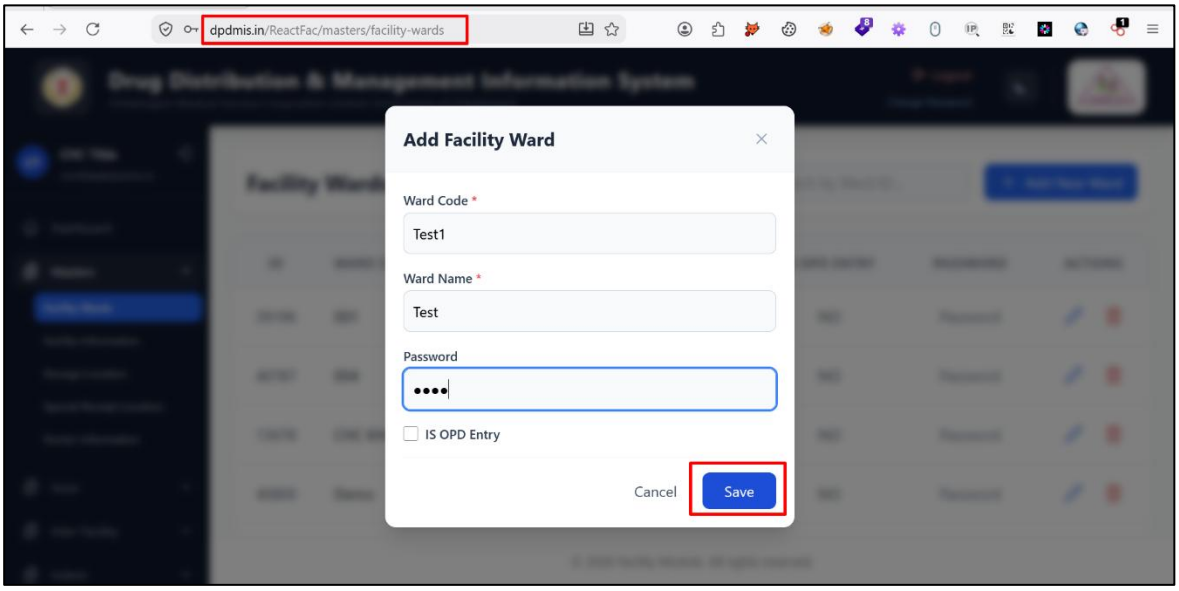


POC 4 - Accessed backup→04-07-19→DirectContract.aspx, which triggered a verbose error message disclosing the backup directory name, source code file, internal file path and ASP.NET framework version.

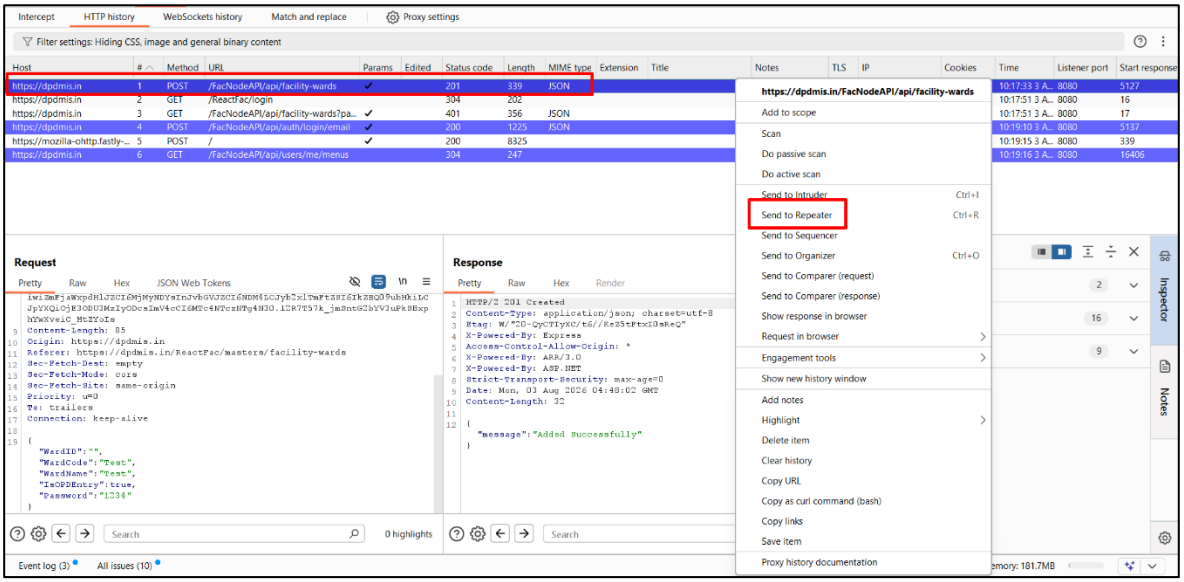
Vulnerability Point No. 4	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/masters/facility-wards https://dpdmis.in/ReactFac/dashboard
Vulnerability Name	Improper session management
CWE/CVE	CWE-384
Severity	**Medium**
Status	**Open**
Description	The application implements improper session management. It fails to invalidate authenticated sessions after user logout, allowing previously captured authenticated requests to be replayed successfully. Additionally, user sessions remain active even after prolonged periods of inactivity, indicating that appropriate session timeout controls are not enforced. These issues allow authenticated sessions to remain valid beyond their intended lifetime.
Impact	An attacker with access to a valid session or captured request may continue performing authenticated actions after logout or during extended inactivity, resulting in unauthorized access and misuse of the application.
Recommendation	Invalidate all active sessions upon logout, reject replayed requests, and enforce a secure idle session timeout (e.g., 15–30 minutes). Ensure expired or logged-out sessions cannot access protected resources.
Proof of Concept	

Note: The below POC shows the improper session management issue.

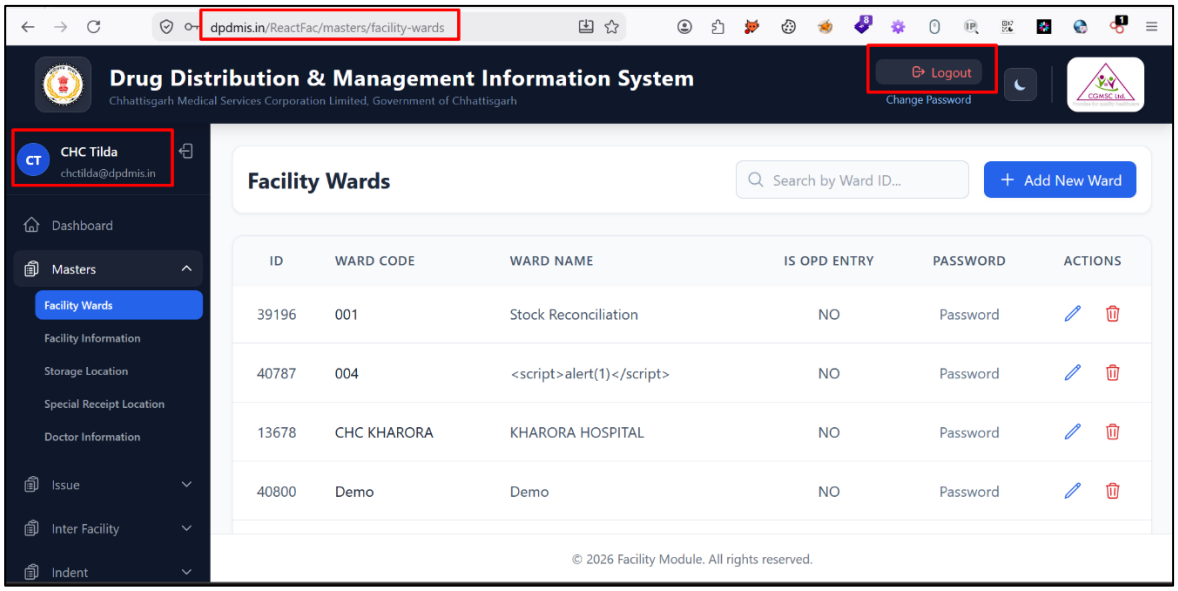
Issue 1: Session Remains Valid After Logout



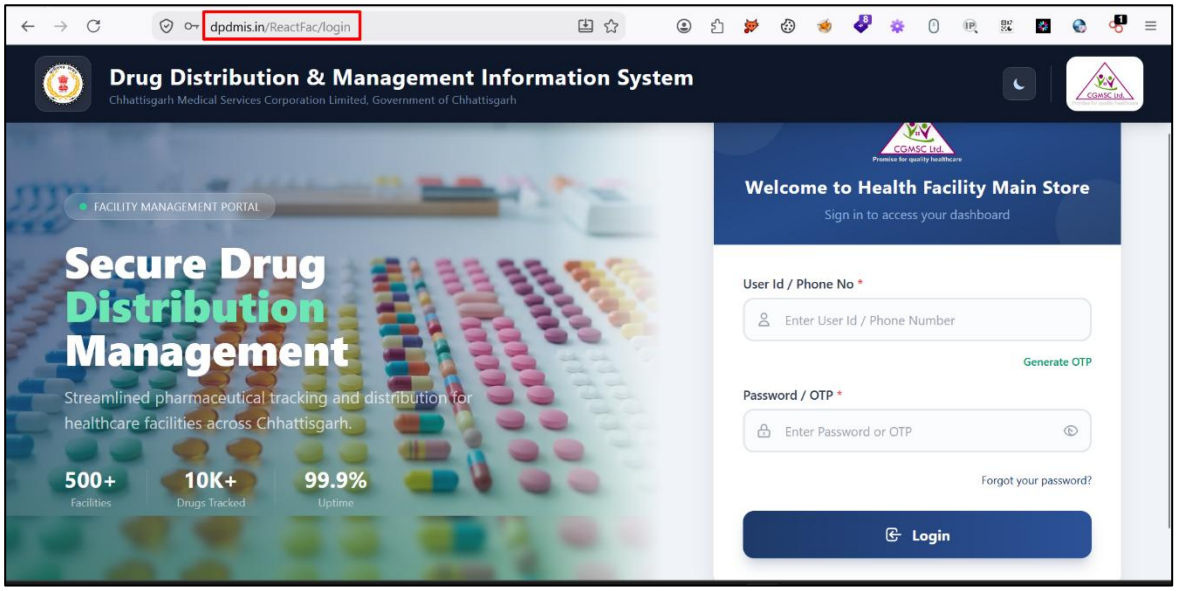
POC 1 - Navigated to Masters → Facility Wards → Add New Ward and entered the required details.



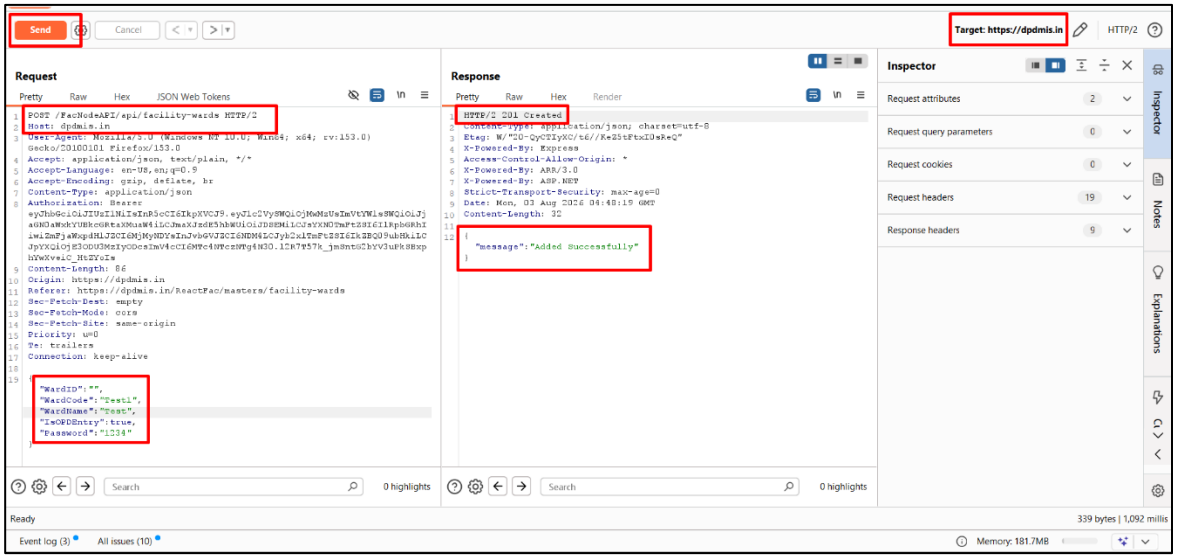
POC 2 - Intercepted the POST /FacNodeAPI/api/facility-wards request in Burp suite and sent it to repeater for further testing.



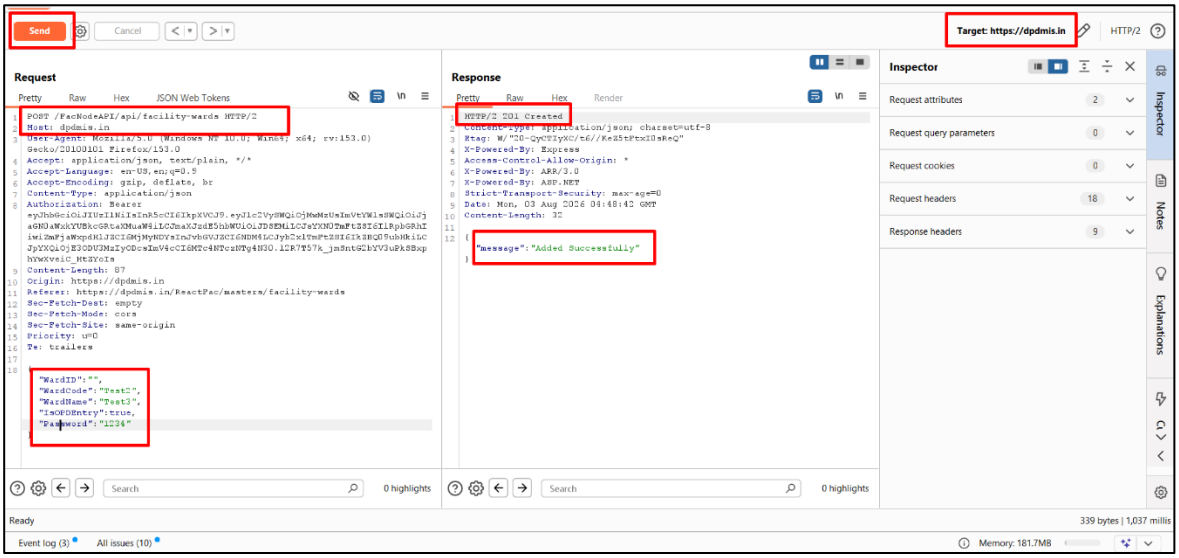
POC 3 - Logged out of the application from the browser after intercepting the Add Facility Ward request.



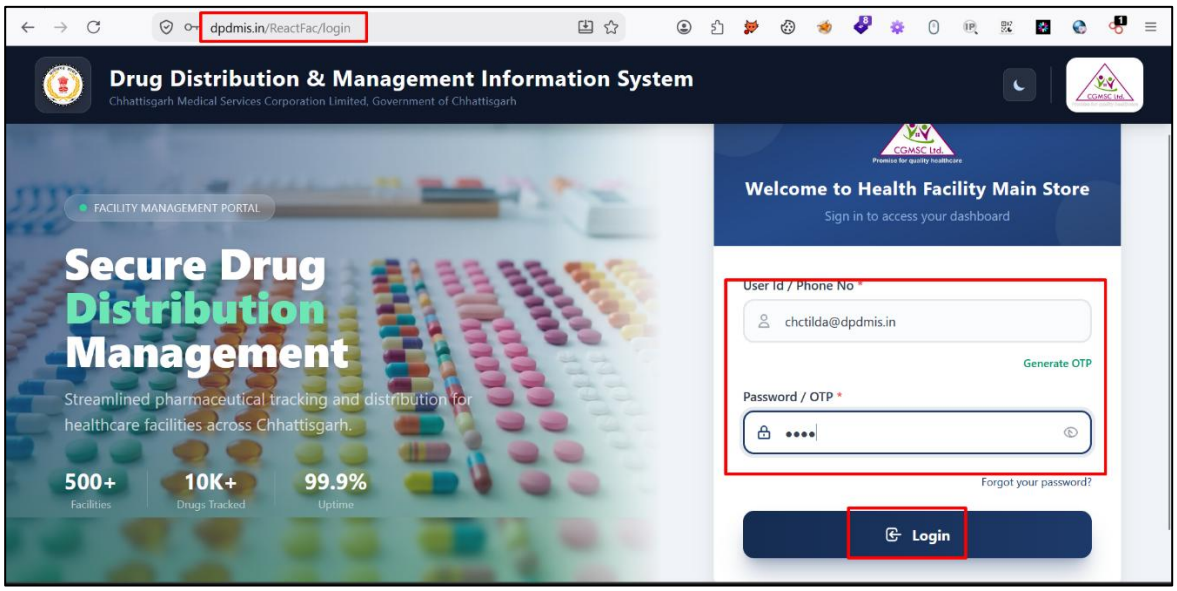
POC 4 - Verified that the application redirected to the login page after logout, confirming that the browser session had been terminated.



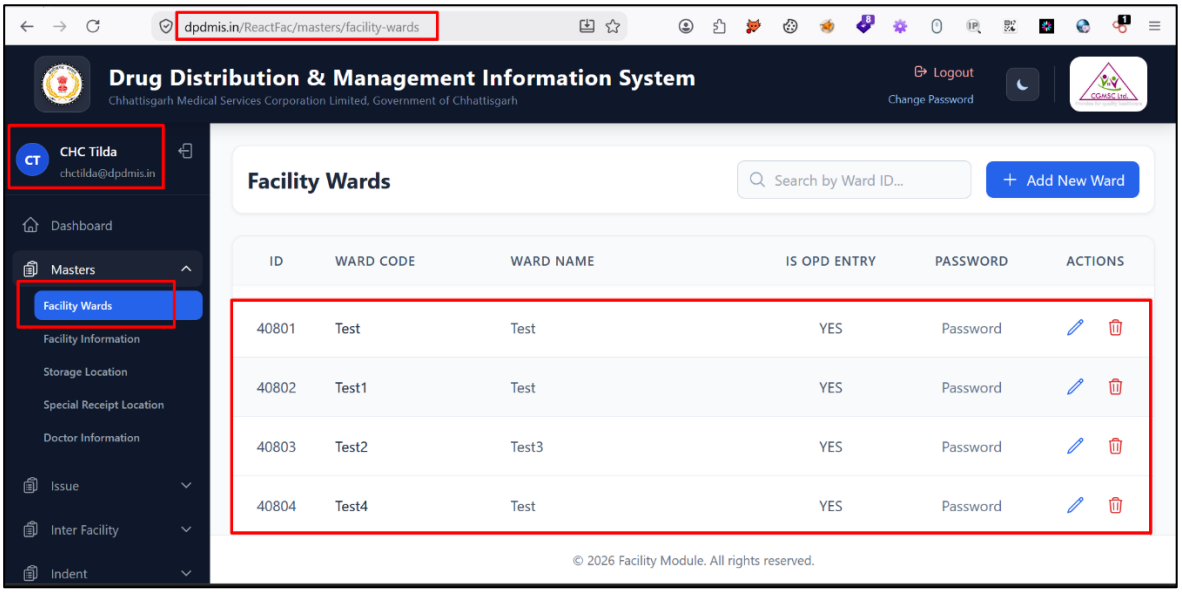
POC 5 - Replayed the previously captured POST /FacNodeAPI/api/facility-wards request from burp repeater after logout and observed that the server responded with a success message indicating that the ward was created successfully.



POC 6 - Replayed the modified request multiple times from burp repeater, and the application successfully created multiple facility wards after logout.

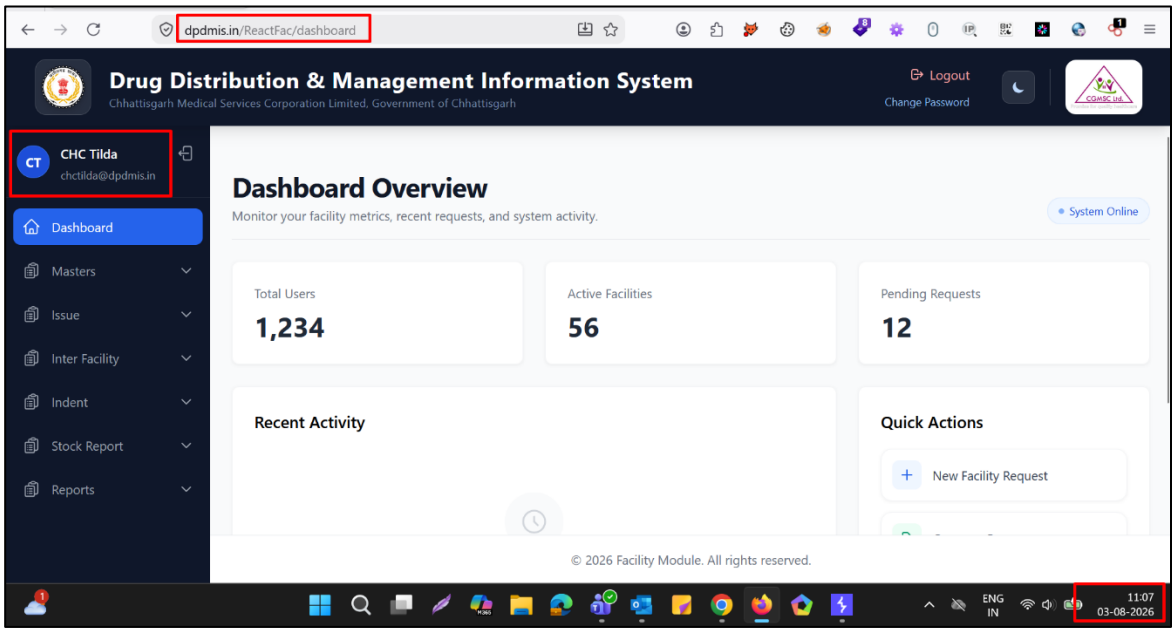


POC 7 - Logged into the application again using valid user credentials.

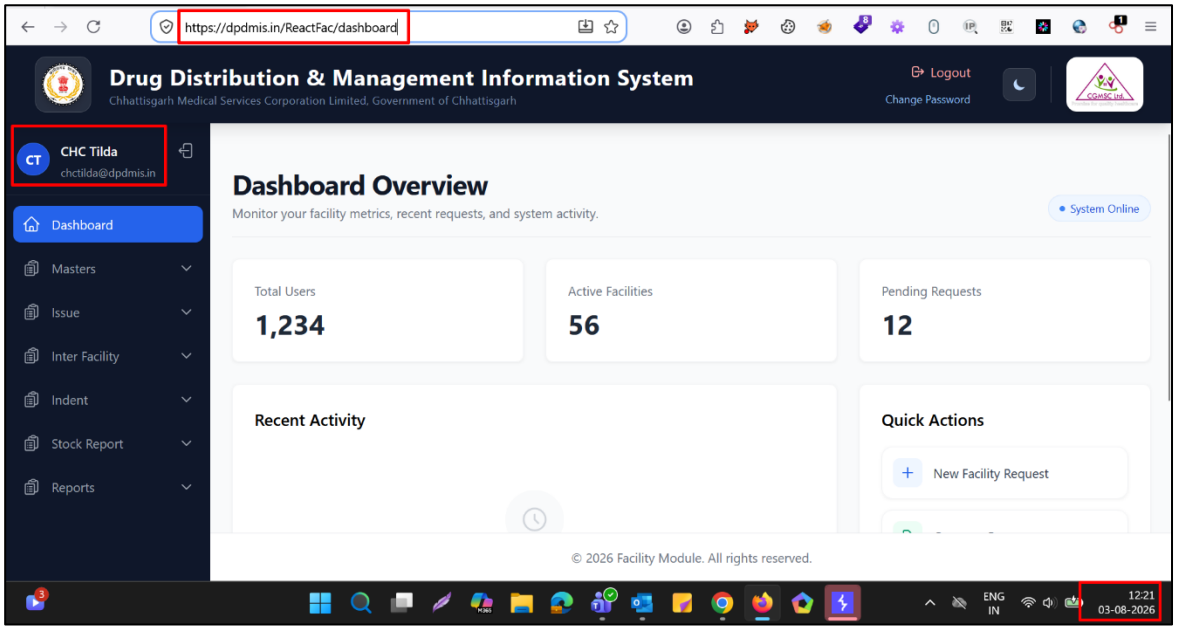


POC 8 - After logging into the application, verified that all the facility wards created through the replayed requests were successfully listed in the application interface.

Issue 2: Improper Session Timeout



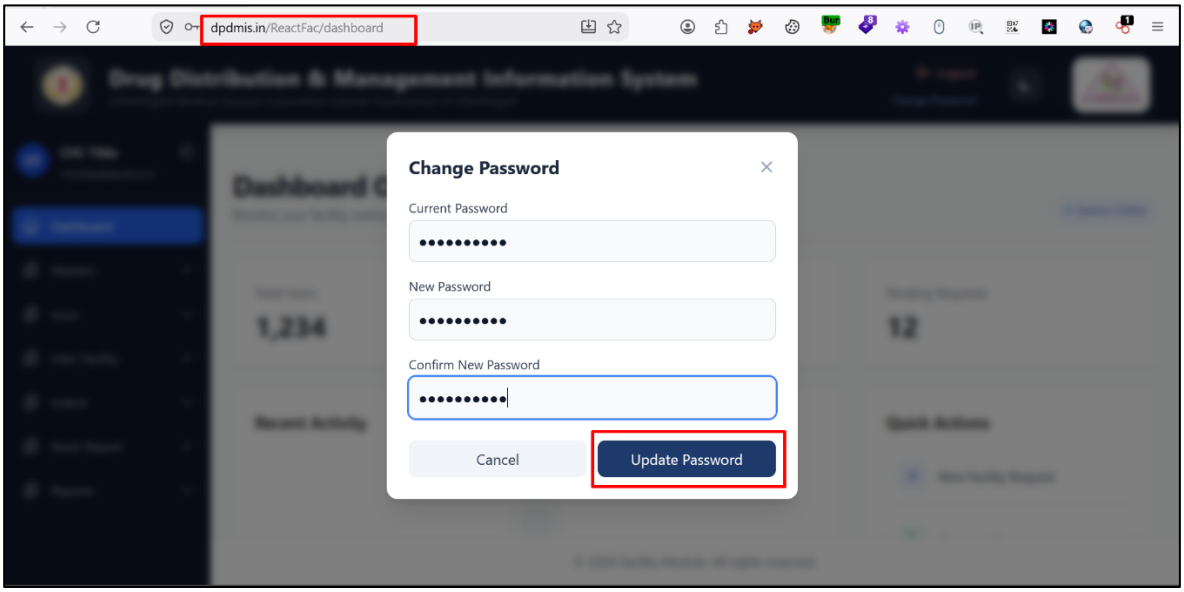
POC 9 - Logged into the application successfully and recorded the login time to verify the session timeout behavior.



POC 10 - Recorded the time after one hour of inactivity and confirmed that the authenticated session was still active.

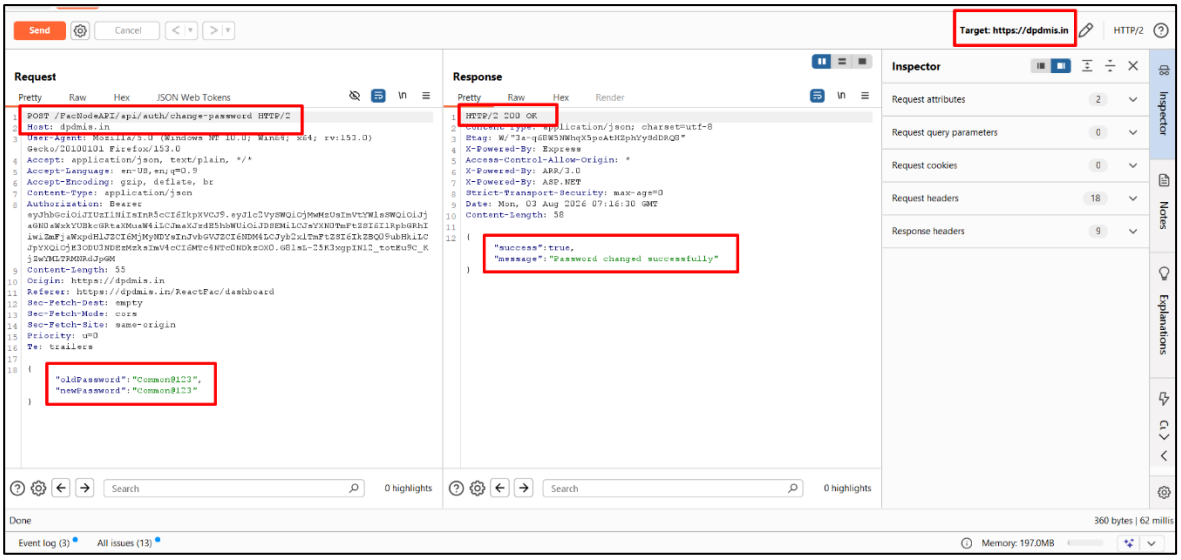
Vulnerability Point No. 5	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/dashboard https://dpdmis.in/FacNodeAPI/api/auth/change-password
Vulnerability Name	Improper password policy enforcement
CWE/CVE	CWE-521
Severity	**Medium**
Status	**Open**
Description	The application does not adequately enforce password security requirements. During testing, it was observed that: • The application accepts weak passwords that do not meet recommended complexity requirements. • The application allows users to set the new password identical to the current password during the password change process.
Impact	• Users may continue using weak or easily guessable passwords. • Password change functionality becomes ineffective, as users can reuse their existing password. • These weaknesses increase the risk of unauthorized account access through password guessing or brute-force attacks.
Recommendation	• Enforce a strong password policy (minimum length, uppercase, lowercase, number, and special character). • Prevent users from setting the new password equal to the current password. • Optionally implement password history to prevent reuse of recent passwords.
Proof of Concept	

Note: The below POC shows improper password policy enforcement issue.

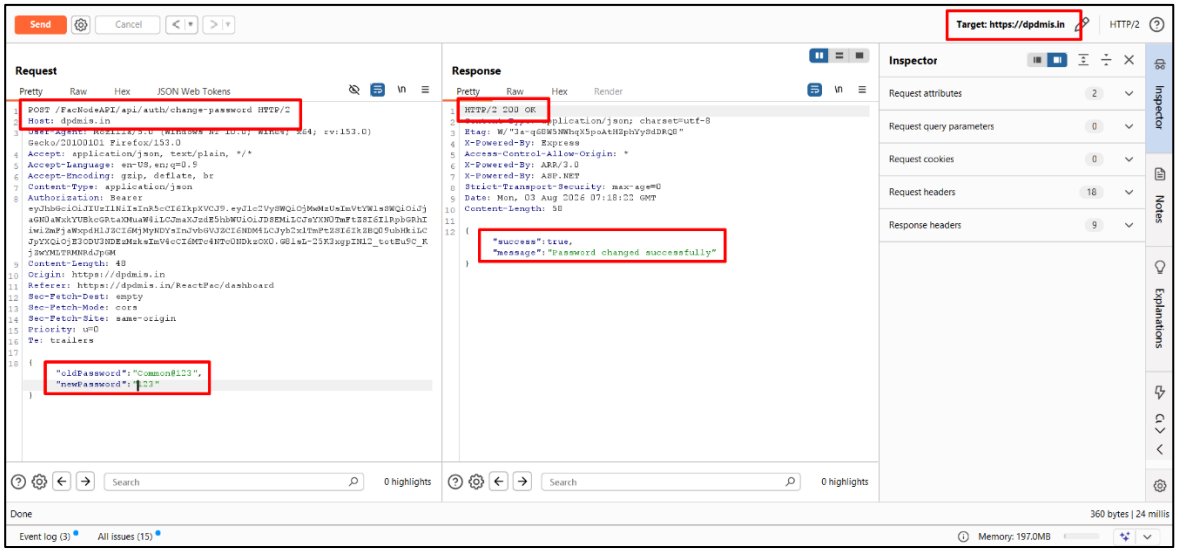


POC 1 – Navigate to Change Password → Enter the same value in the Current Password, New Password,

and Confirm New Password fields → Click Update Password.



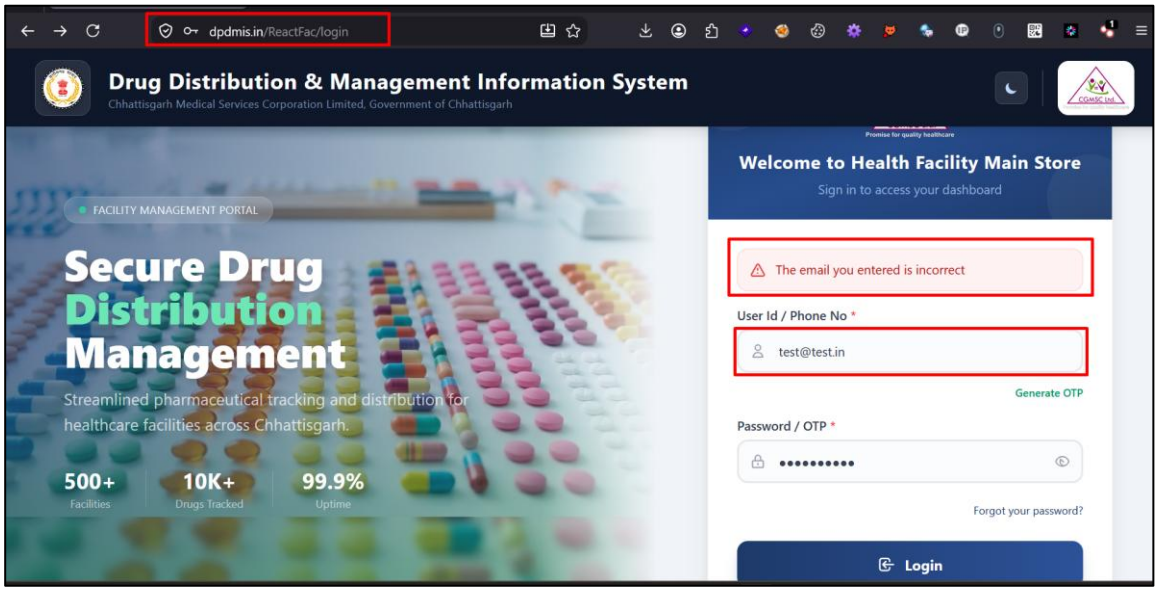
POC 2 – Capture the password change request using an intercepting proxy and observe that the server responds with the message password changed successfully.



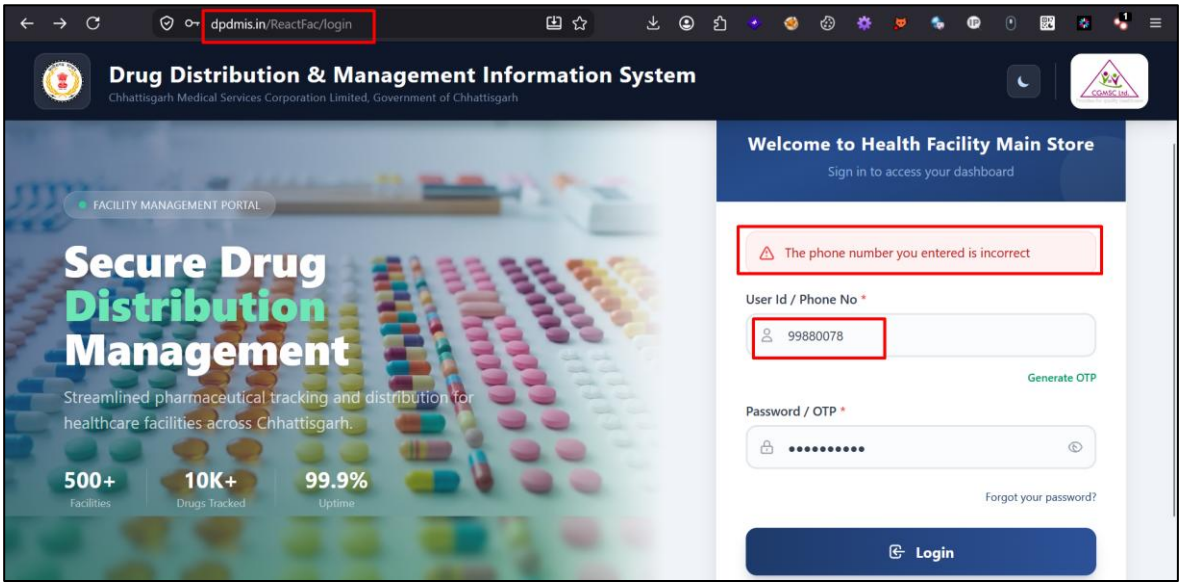
POC 3 - Capture the password change request → Change the New Password to 123 → Forward the request → Observe that the weak password is accepted and the password is changed successfully.

Vulnerability Point No. 6	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login
Vulnerability Name	Username and password enumeration
CWE/CVE	CWE-203
Severity	Low
Status	Open
Description	The application discloses different responses for valid and invalid usernames or passwords during the authentication process. This allows an attacker to determine whether a username exists in the system based on the application's error messages or behavior.
Impact	An attacker may enumerate valid usernames and use them to perform password guessing, brute-force attacks, credential stuffing, or targeted attacks against legitimate users, increasing the risk of unauthorized account access.
Recommendation	Implement generic authentication error messages such as "Invalid username or password" for all login failures. Ensure that the application's response, status code, and response time remain consistent regardless of whether the username or password is incorrect. Additionally, implement account lockout, CAPTCHA, and rate-limiting controls to prevent automated attacks.
Proof of Concept	

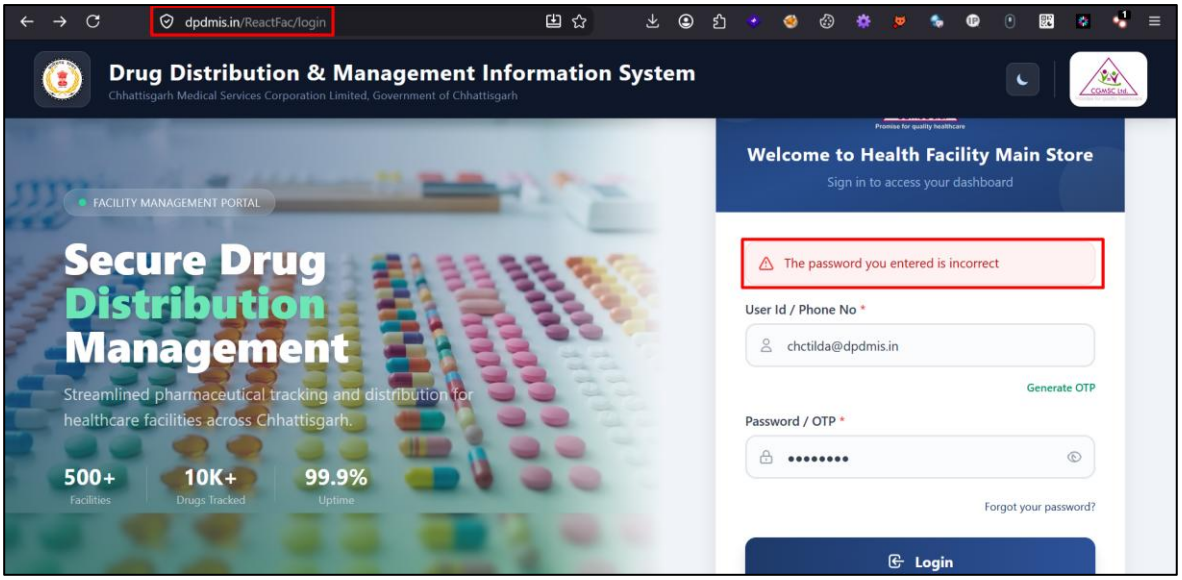
Note: The below POC shows the username and password enumeration issue.



POC 1 – The above POC shows username enumeration.



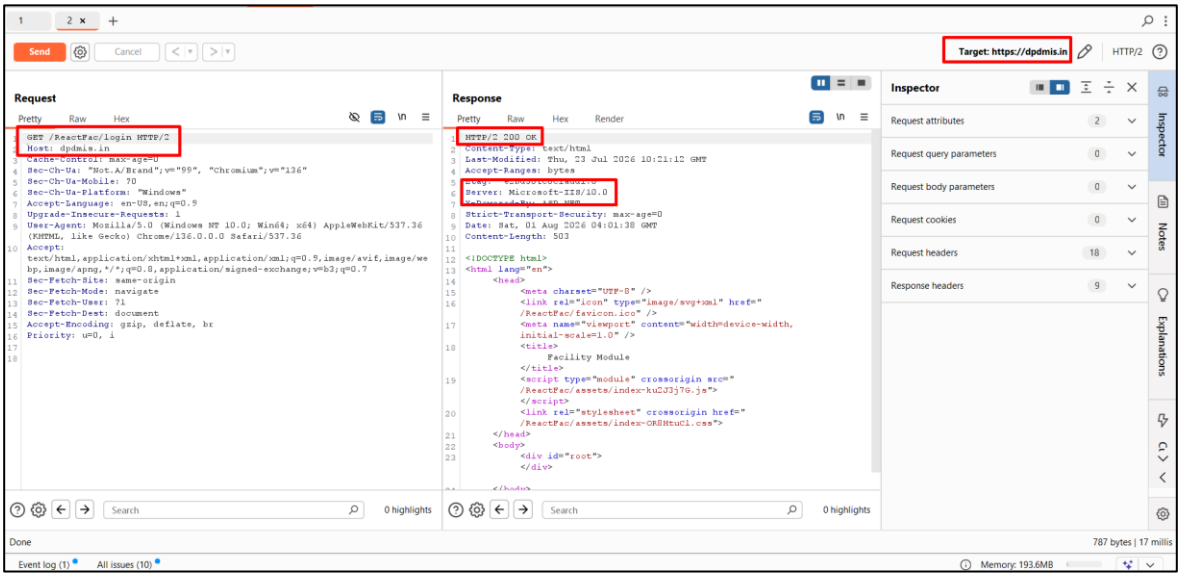
POC 2 - The above POC shows username enumeration.



POC 3 - The above POC shows password enumeration.

Vulnerability Point No. 7	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login
Vulnerability Name	Server version disclosure
CWE/CVE	CWE-200
Severity	Low
Status	Open
Description	The server reveals version information through HTTP headers or error messages.
Impact	Attackers may use version details to identify known vulnerabilities.
Recommendation	Remove or obfuscate server version information from responses and headers.
Proof of Concept	

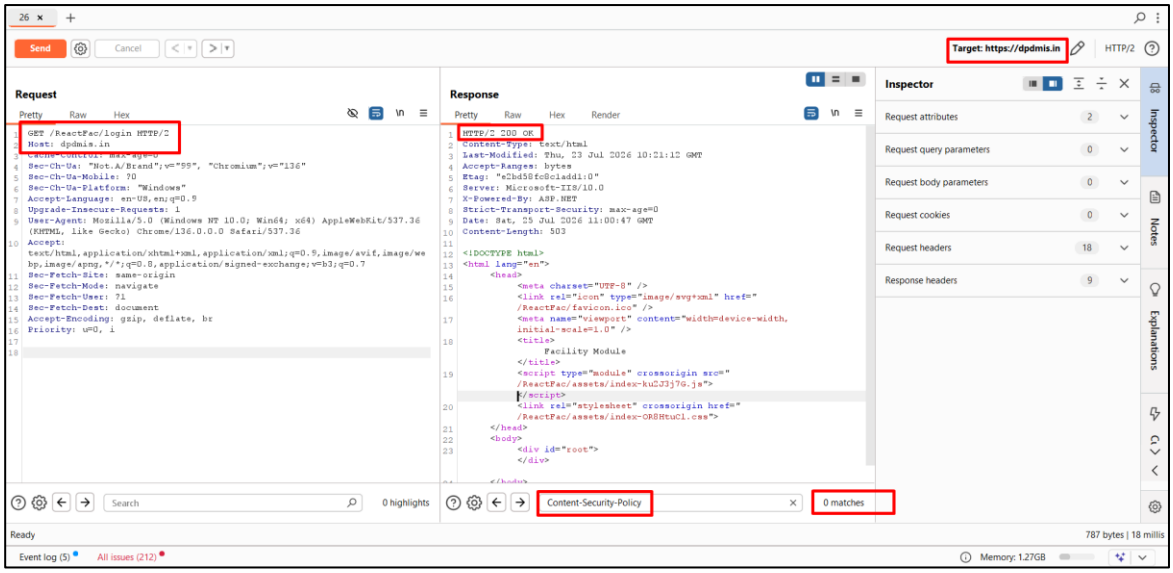
Note: The below POC shows that server version is disclosed.



POC 1 - Microsoft-IIS version 10.0 is disclosed.

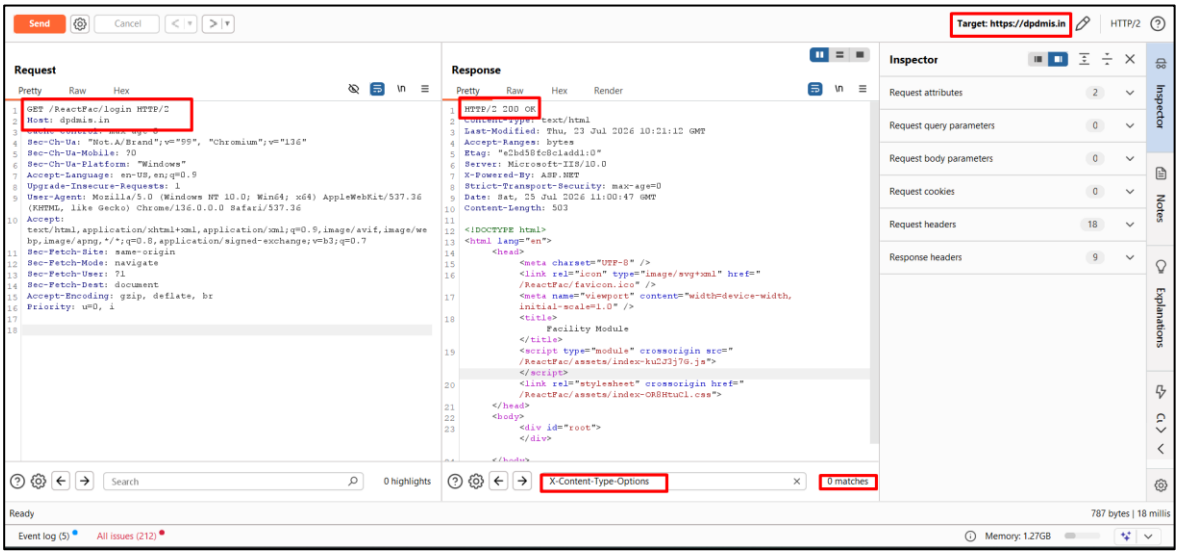
Vulnerability Point No. 8	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login
Vulnerability Name	Content-Security-Policy (CSP) header missing
CWE/CVE	CWE-693
Severity	**Low**
Status	**Open**
Description	The application does not implement a Content-Security-Policy (CSP) header. Without CSP, the browser cannot restrict the sources of scripts, styles, or other resources.
Impact	This increases the risk of client-side attacks, such as Cross-Site Scripting (XSS) or injection of malicious content.
Recommendation	Implement a strict Content Security Policy header to control which sources are allowed to load scripts, styles, images, and other resources.
Proof of Concept	

Note: The below POC shows that Content-Security-Policy (CSP) header is missing.



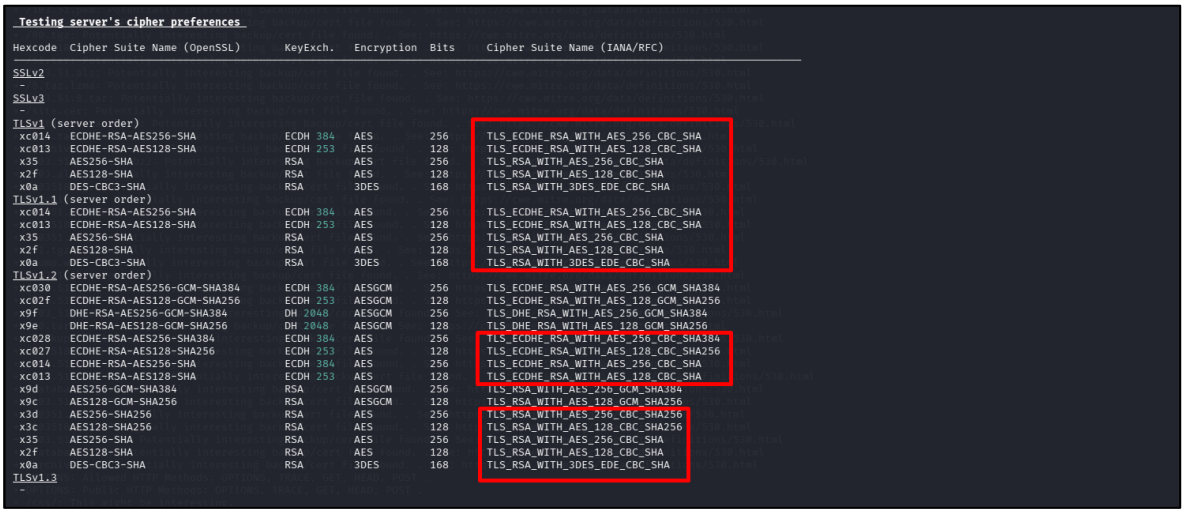
Vulnerability Point No. 9	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login
Vulnerability Name	X-Content-Type-Options header missing
CWE/CVE	CWE-693
Severity	**Low**
Status	**Open**
Description	The application does not set the X-Content-Type-Options: nosniff header. Without it, browsers may incorrectly interpret files and execute them as a different MIME type
Impact	This can allow attackers to bypass content type restrictions, potentially leading to XSS or execution of malicious content.
Recommendation	Set the X-Content-Type-Options: nosniff header for all responses to prevent MIME type sniffing.
Proof of Concept	

Note: The below POC shows that X-Content-Type-Options header is missing.

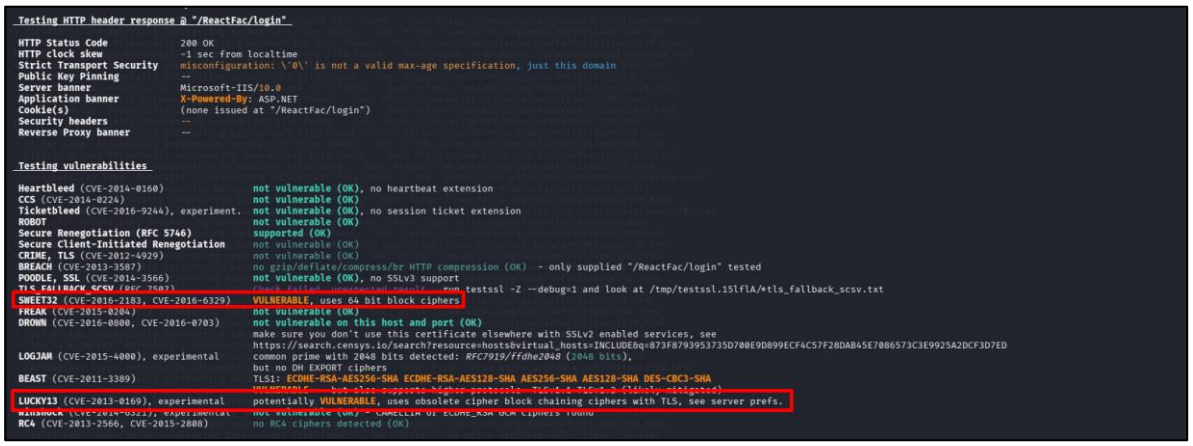


Vulnerability Point No. 10	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login
Vulnerability Name	Weak CBC mode ciphers
CWE/CVE	CWE-327
Severity	Low
Status	Open
Description	The server supports weak CBC-mode cipher suites that are known to be vulnerable to cryptographic attacks.
Impact	Attackers may exploit these weaknesses to decrypt sensitive information or compromise the confidentiality of encrypted communications.
Recommendation	Weak cipher suites should be disabled and replaced with strong, modern encryption algorithms such as AES-GCM or ChaCha20 following industry best practices.
Proof of Concept	

Note: The below POC shows Weak CBC mode ciphers.



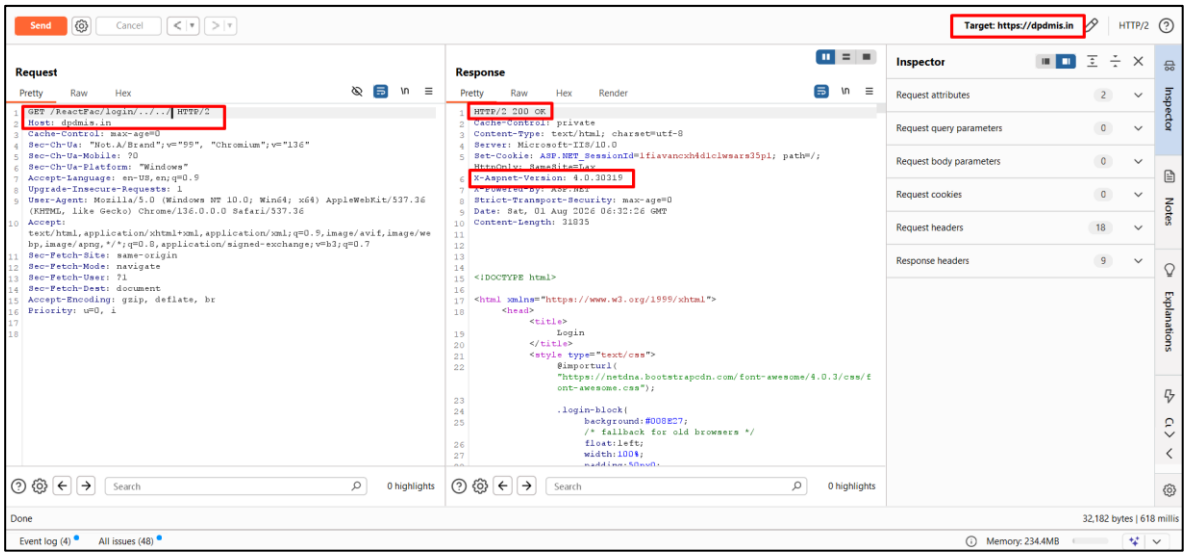
POC 1 - The above POC shows that weak CBC ciphers are used.



POC 2 - The above POC shows that the application is vulnerable to SWEET32 and LUCKY13.

Vulnerability Point No. 11	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login/./../
Vulnerability Name	X-AspNet version disclosure
CWE/CVE	CWE-200
Severity	Low
Status	Open
Description	The application discloses the X-AspNet-Version HTTP response header, revealing the ASP.NET framework version in use.
Impact	Attackers can fingerprint the application framework and target version-specific vulnerabilities, increasing the attack surface.
Recommendation	Remove or suppress the X-AspNet-Version header in production and ensure the framework is regularly updated and hardened.
Proof of Concept	

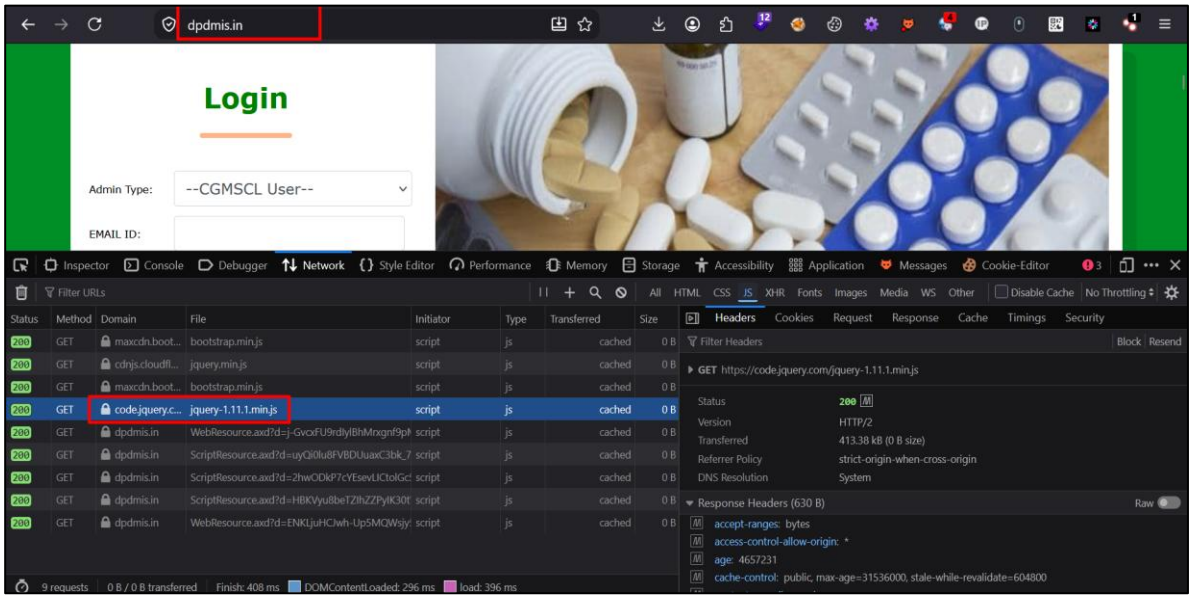
Note: The below POC shows that X-AspNet version is disclosed.



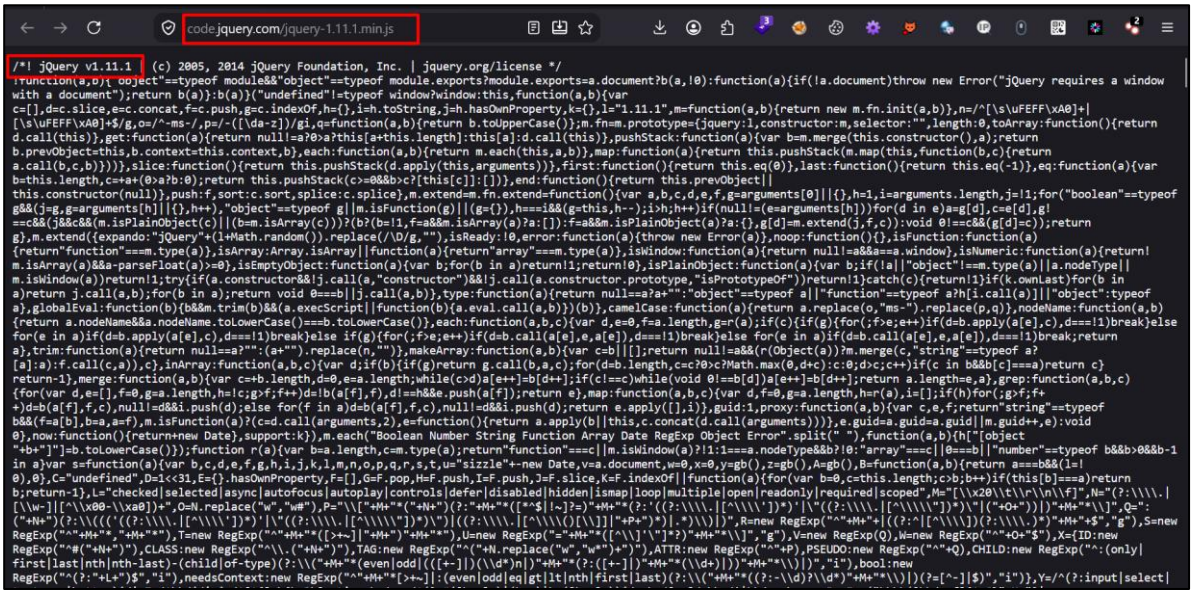
POC 1 – Add /../../ at the end of the GET request, at that time the X-Aspnet-Version is disclosed.

Vulnerability Point No. 12	
Affected URL/ Application/Point / Path	https://code.jquery.com/jquery-1.11.1.min.js https://dpdmis.in/common/JQuery/JQuery.js
Vulnerability Name	Use of outdated jQuery library
CWE/CVE	CWE-1104
Severity	Low
Status	Open
Description	The application is using an outdated version of jQuery. Older versions may contain publicly known security vulnerabilities.
Impact	Attackers may exploit known weaknesses in outdated libraries, which could affect the security and integrity of the application.
Recommendation	Upgrade jQuery to the latest stable version. Regularly review and update third-party libraries to reduce security risks.
Proof of Concept	

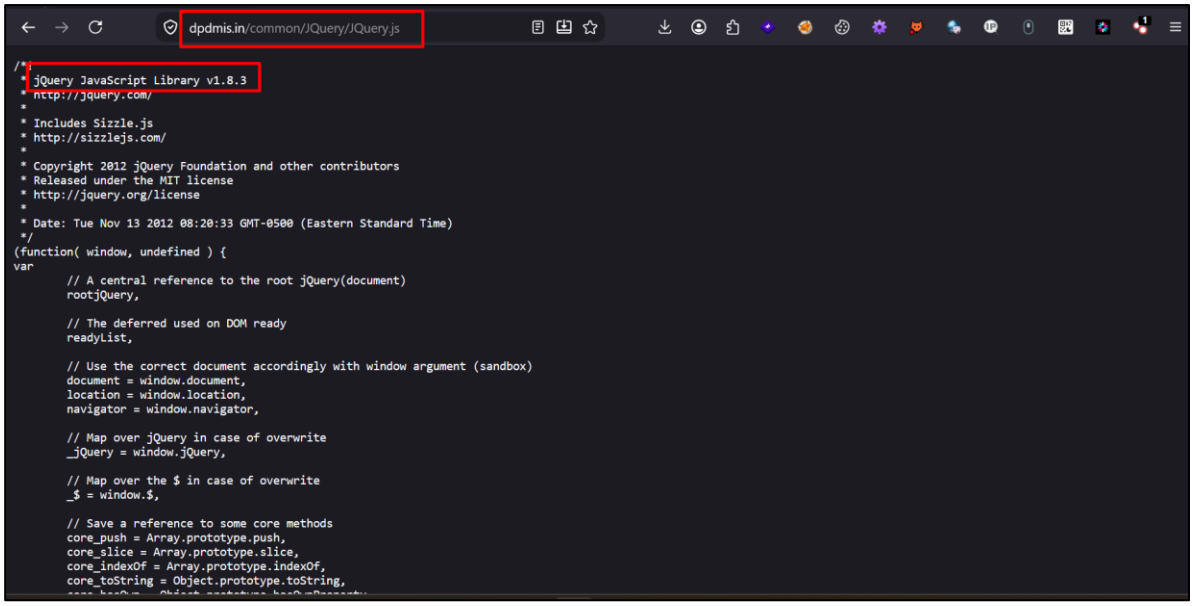
Note: The below POC shows that application is using an outdated version of jQuery.



POC 1 - The above POC shows the use of outdated jQuery version.



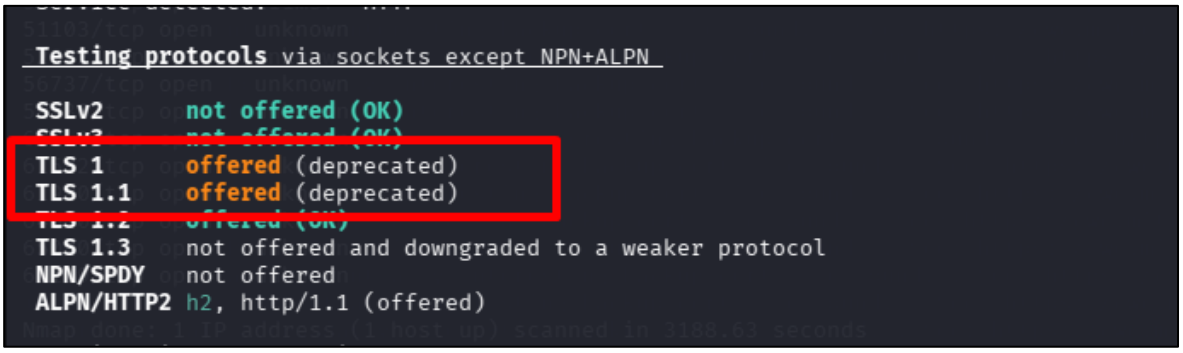
POC 2 - The above POC shows that outdated jQuery version 1.11.1 is used.



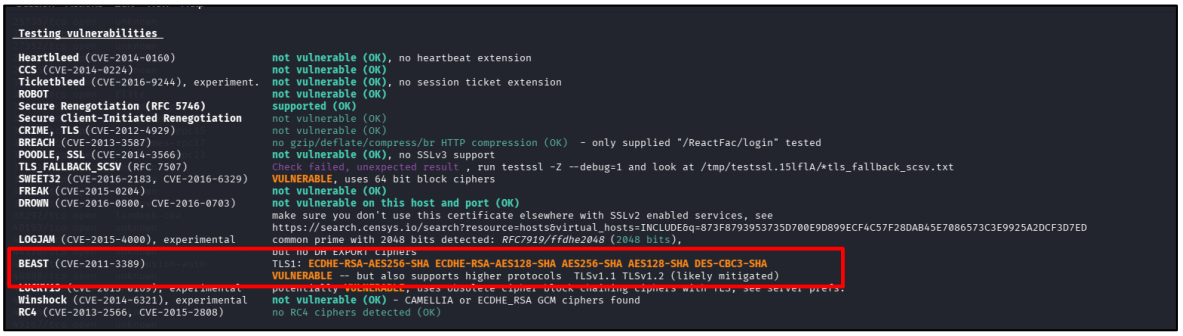
POC 3 - The above POC shows that outdated jQuery version 1.8.3 is used.

Vulnerability Point No. 13	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login
Vulnerability Name	Weak TLS ciphers
CWE/CVE	CWE-327
Severity	Low
Status	Open
Description	The server supports weak or deprecated TLS/SSL cipher suites and protocols, reducing the strength of encrypted communications.
Impact	Attackers may decrypt traffic, perform man-in-the-middle attacks, and expose sensitive data.
Recommendation	Disable weak ciphers and older protocols like SSLv2, SSLv3, TLS 1.0, and TLS 1.1.Use only strong ciphers with TLS 1.2 or TLS 1.3 enabled.
Proof of Concept	

Note: The below POC shows that weak TLS ciphers are used.



POC 1 – TLS 1 and TLS 1.1 deprecated protocols are offered.

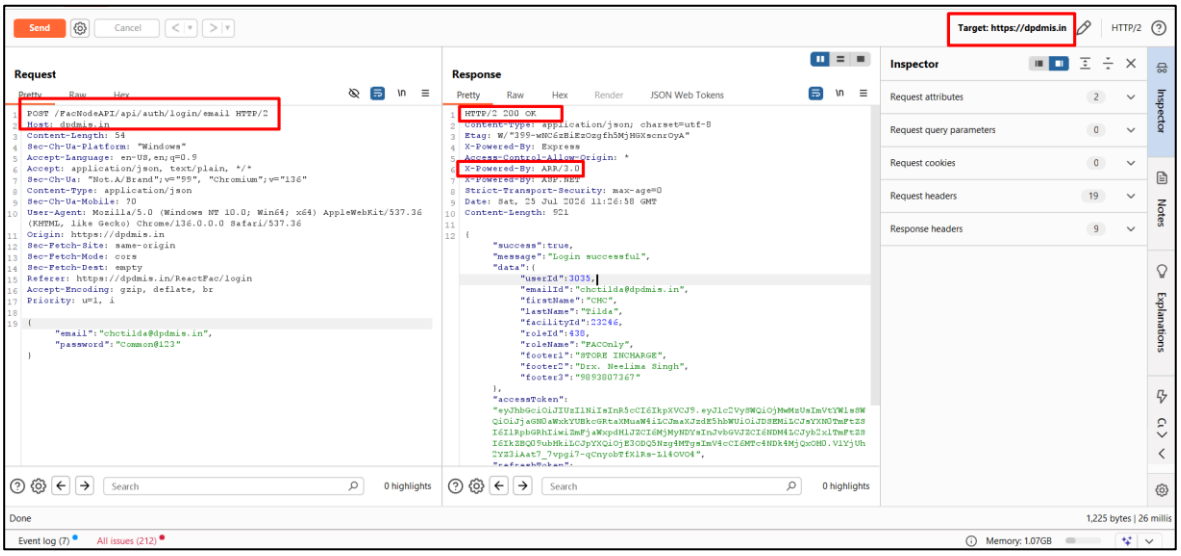


POC 2 – The above POC shows that the application is vulnerable to BEAST.

Vulnerability Point No. 14	
Affected URL/ Application/Point / Path	https://dpdmis.in/FacNodeAPI/api/auth/login/email https://dpdmis.in/FacNodeAPI/api/warehouse-receipt/fin-years
Vulnerability Name	Technology version information disclosure
CWE/CVE	CWE-200
Severity	**Low**
Status	**Open**
Description	The application discloses technology and software version information through HTTP response headers, including the web server, application framework, routing components, and runtime environment. Such disclosures enable attackers to fingerprint the application's technology stack and identify publicly known vulnerabilities associated with the exposed software versions.
Impact	The disclosed information may assist attackers in reconnaissance, facilitate identification of known vulnerabilities, and enable more targeted attacks against the application's underlying technologies.
Recommendation	Remove or suppress unnecessary HTTP response headers (e.g., Server, X-Powered-By, X-AspNet-Version, X-ARR-Version) that reveal technology version information, and ensure all software components are updated to supported and secure versions.

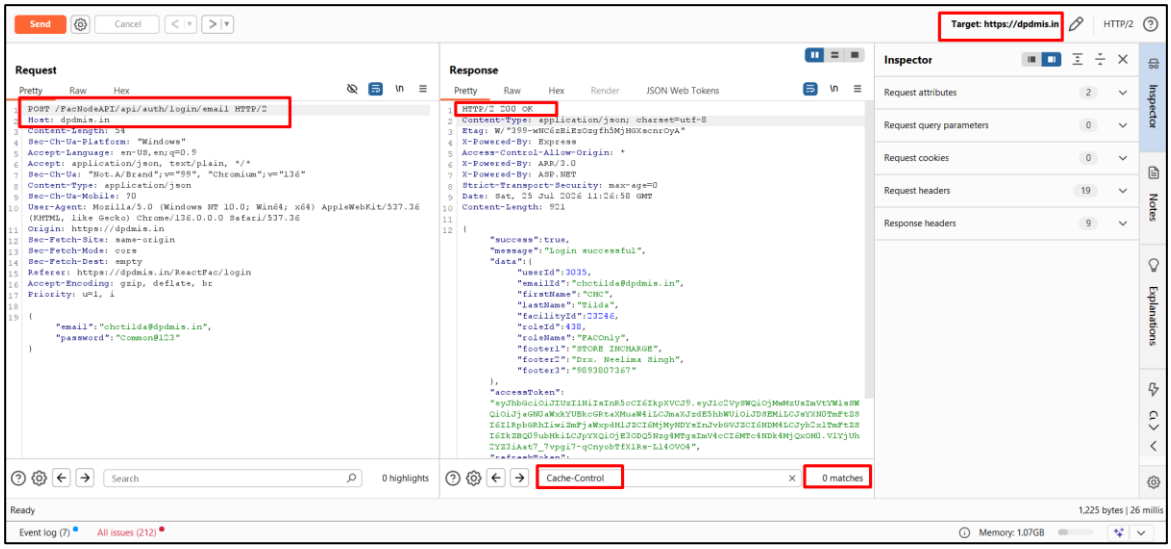
Proof of Concept

Note: The below POC shows that technology version information is disclosed.



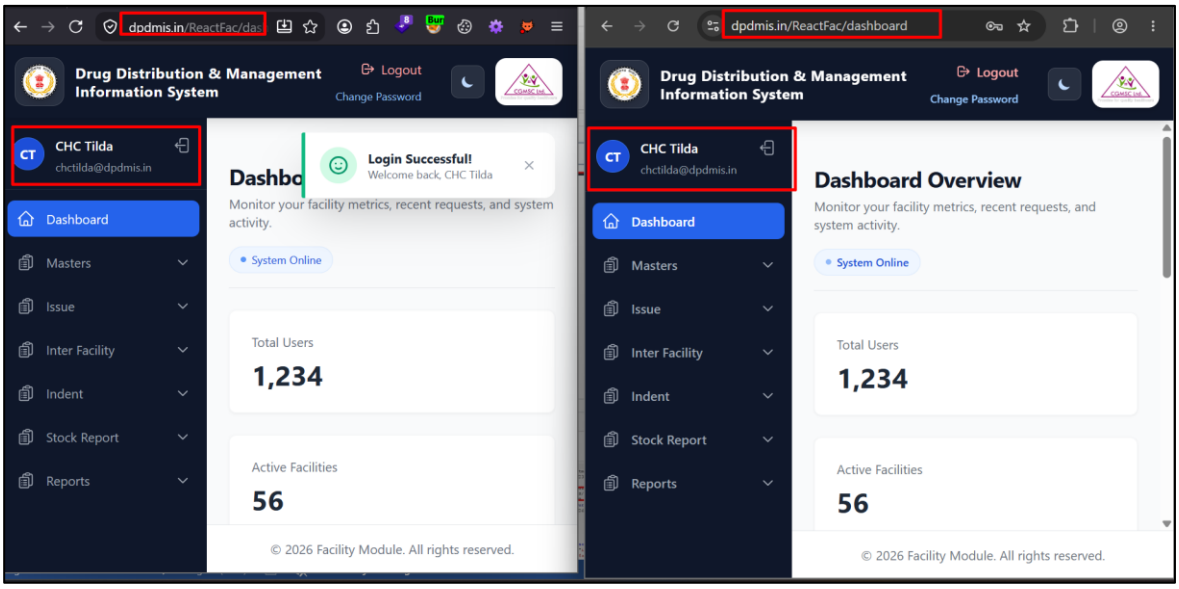
Vulnerability Point No. 15	
Affected URL/ Application/Point / Path	https://dpdmis.in/FacNodeAPI/api/auth/login/email
Vulnerability Name	Cache control header missing
CWE/CVE	CWE-525
Severity	Low
Status	Open
Description	The application does not include the Cache-Control header in its response.
Impact	Without proper Cache-Control, sensitive information may be stored in the browser cache or shared systems. This could lead to unauthorized access to cached data.
Recommendation	Configure the application to include appropriate Cache-Control directives such as no-store or no-cache for sensitive pages to prevent improper data storage.
Proof of Concept	

Note: The below POC shows that cache-control header is missing.



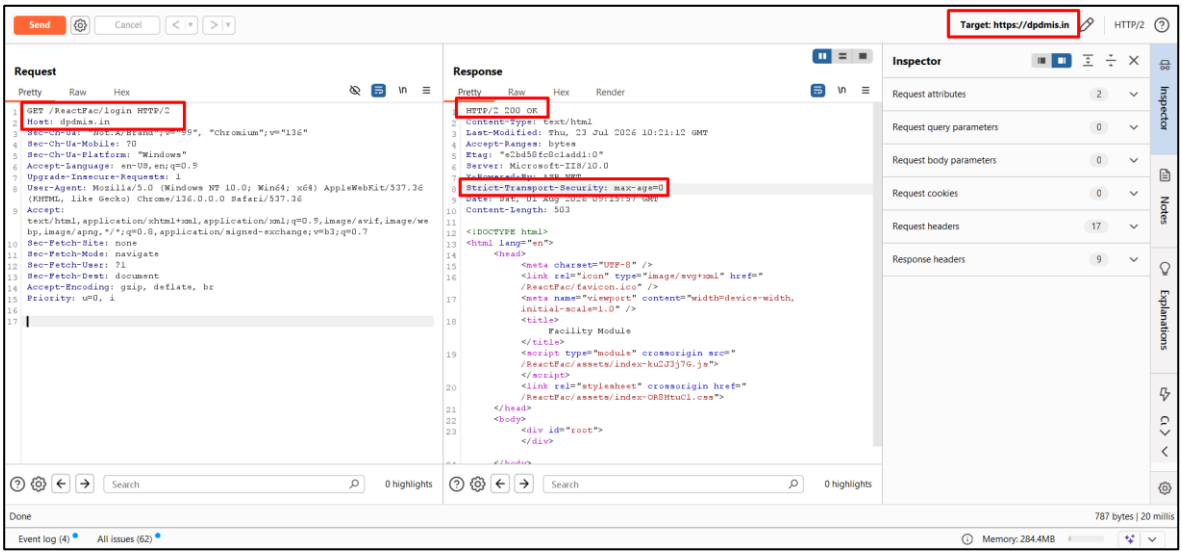
Vulnerability Point No. 16	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/dashboard
Vulnerability Name	Concurrent login
CWE/CVE	CWE-287
Severity	Low
Status	Open
Description	The application allows the same user credentials to be used for multiple active sessions simultaneously without restriction.
Impact	This increases the risk of unauthorized account usage, makes it harder to detect compromised credentials, and may enable session abuse or misuse.
Recommendation	It is recommended to limit the number of concurrent sessions per user, implement session management controls, and notify users when multiple logins are detected.
Proof of Concept	

Note: The below POC shows that application allows simultaneous logins for same user account.

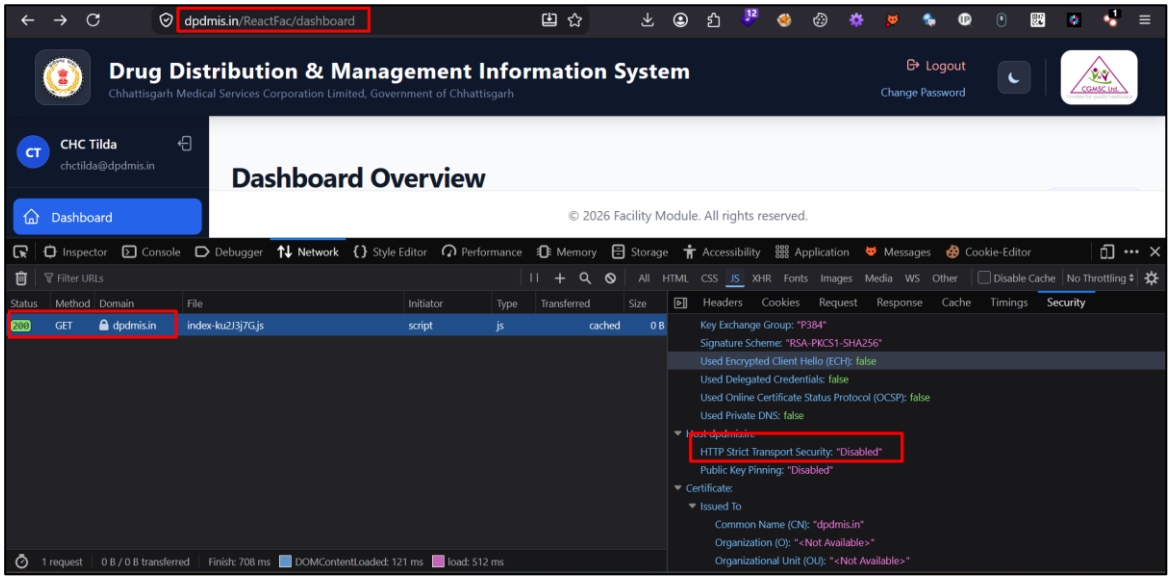


Vulnerability Point No. 17	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login
Vulnerability Name	Improper implementation of HTTP Strict Transport Security (HSTS) header
CWE/CVE	CWE-693
Severity	Low
Status	Open
Description	The application does not enforce HTTP Strict Transport Security (HSTS). Although the Strict-Transport-Security header is present, it is configured with max-age=0, which instructs browsers to disable HSTS. As a result, browsers do not enforce HTTPS-only communication for subsequent requests.
Impact	Without HSTS enforcement, users may be vulnerable to SSL stripping and protocol downgrade attacks, allowing an attacker in a man-in-the-middle (MITM) position to redirect users from HTTPS to HTTP and potentially intercept or manipulate sensitive information transmitted between the client and the server.
Recommendation	Configure the Strict-Transport-Security header with an appropriate positive max-age value (e.g., max-age=31536000) to enforce HTTPS connections. Additionally, consider enabling the includeSubDomains directive (if applicable) and the preload directive after ensuring all subdomains support HTTPS.
Proof of Concept	

Note: The below POC shows the improper implementation of Strict Transport Security (HSTS) header.



POC 1 - Intercepted the HTTPS response and observed the Strict-Transport-Security header configured with max-age=0

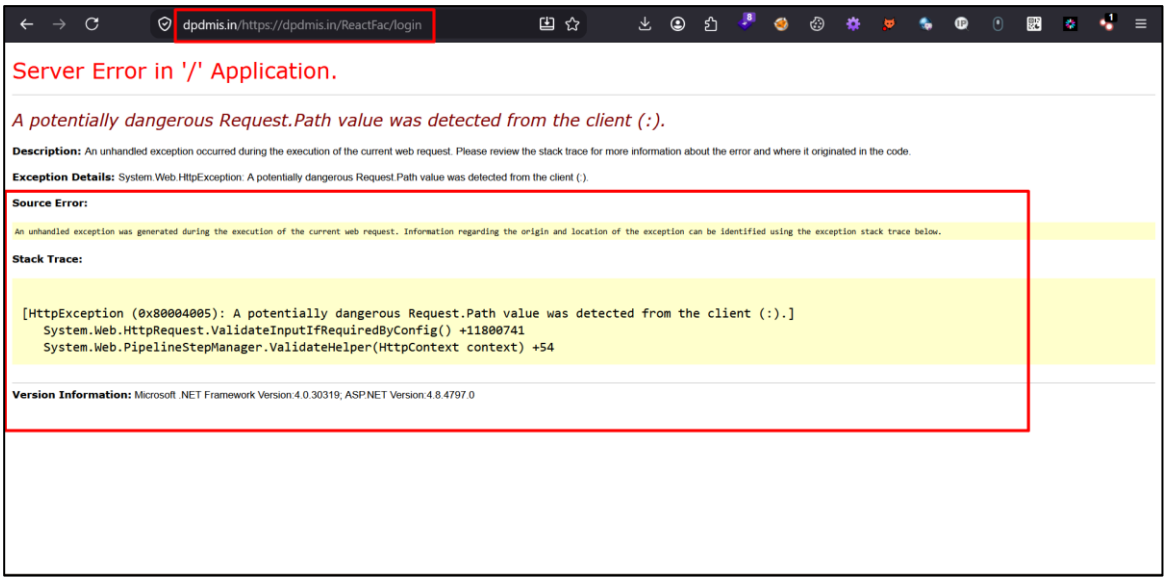


POC 2 - Verified using the security testing tool that HTTP Strict Transport Security (HSTS) is disabled.

Vulnerability Point No. 18	
Affected URL/ Application/Point / Path	https://dpdmis.in/https://dpdmis.in/ReactFac/login
Vulnerability Name	Improper error handling
CWE/CVE	CWE-209
Severity	Low
Status	Open
Description	The application exposes detailed error messages to users or attackers, which may include stack traces, database errors, or system information. This can reveal sensitive implementation details that help an attacker craft further attack.
Impact	Exposing internal error information can allow attackers to gather insights about the system, such as database structure, file paths, or software versions. This can lead to targeted attacks, data leakage, and easier exploitation of other vulnerabilities.
Recommendation	Implement generic error messages for users while logging detailed errors securely on the server. Avoid revealing stack traces, database queries, or system information to end-users. Proper exception handling and input validation should be enforced to reduce the risk of information exposure.

Proof of Concept

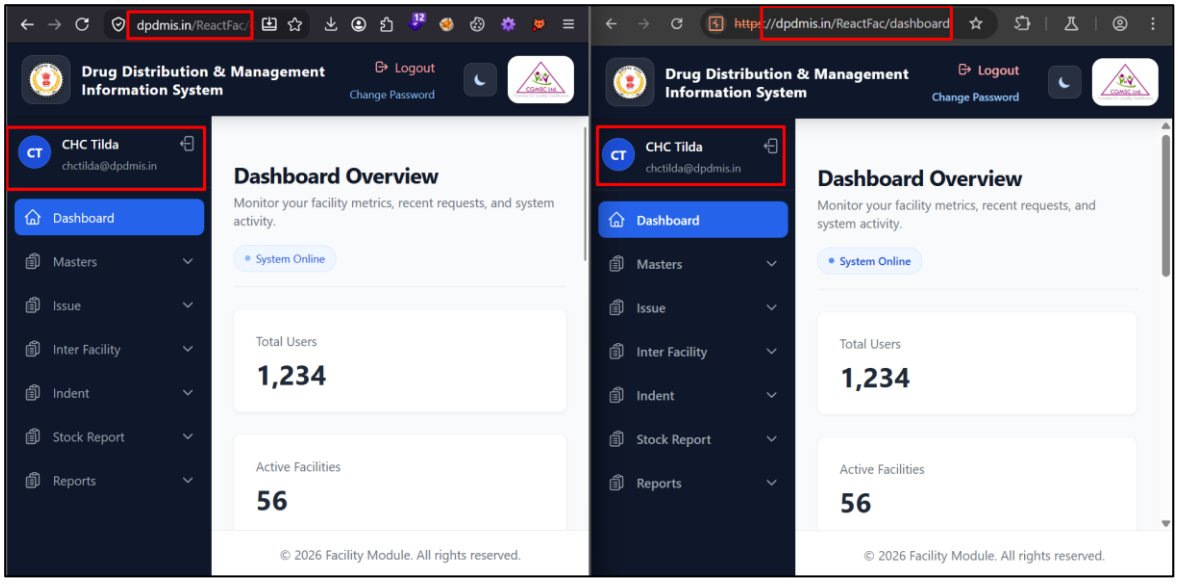
Note: The below POC shows the improper error handling issue.



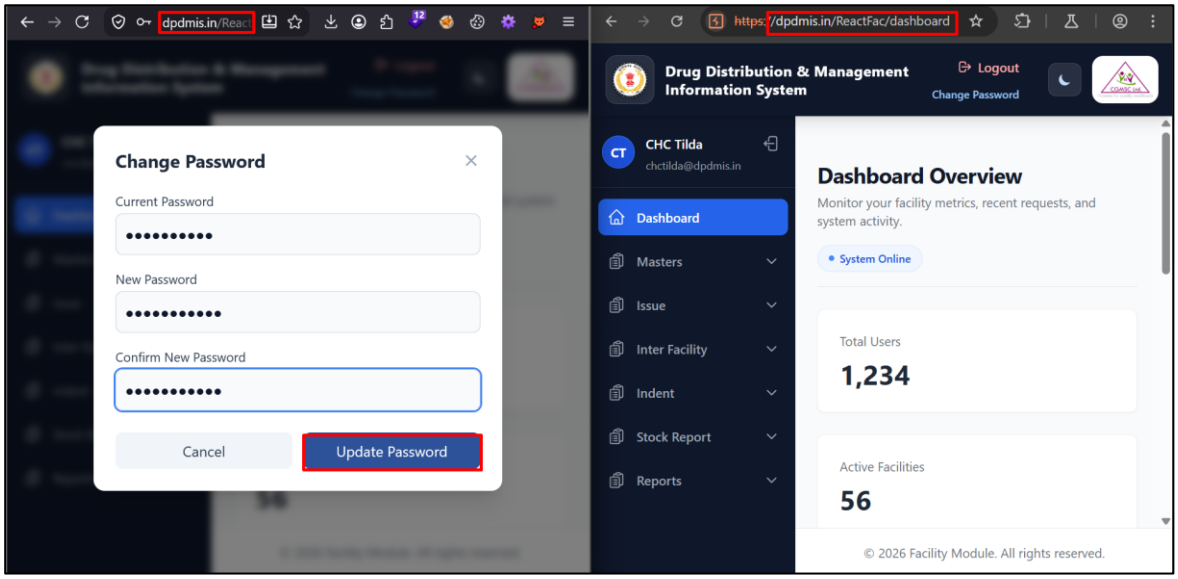
POC 1 – Change the url from https://dpdmis.in/ReactFac/login to https://dpdmis.in/https://dpdmis.in/ReactFac/login at that time the error message is disclosed.

Vulnerability Point No. 19	
Affected URL/ Application/Point / Path	https://dpdmis.in/FacNodeAPI/api/auth/change-password
Vulnerability Name	Old session does not expire after password change
CWE/CVE	CWE-613
Severity	Low
Status	Open
Description	The application does not invalidate existing authenticated sessions after a user changes their password. As a result, any active session established before the password change remains valid and can continue to access the application without requiring re-authentication.
Impact	If an attacker has obtained a valid session token before the password change, they can continue to access the user's account even after the password has been updated. This defeats the purpose of changing the password to terminate unauthorized access and increases the risk of account compromise and unauthorized actions.
Recommendation	Invalidate all active user sessions immediately after a successful password change. Require users to re-authenticate using the new password before accessing the application. Additionally, revoke all existing session tokens, regenerate session identifiers upon re-authentication, and notify users of the password change and any terminated sessions. This ensures that previously established sessions cannot be reused after a password update.
Proof of Concept	

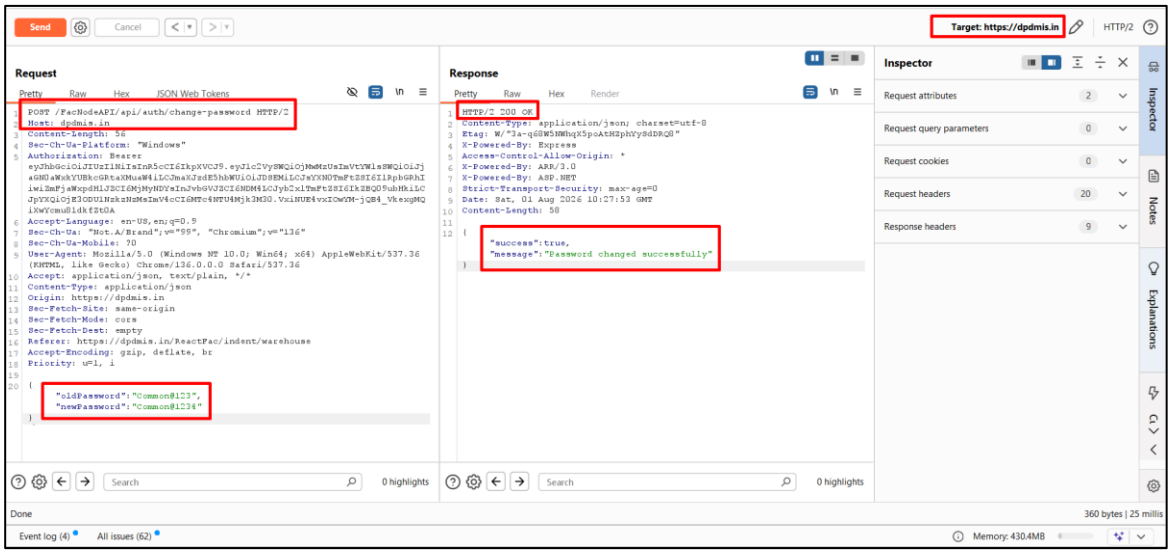
Note: The below POC shows that old session does not expire after password change.



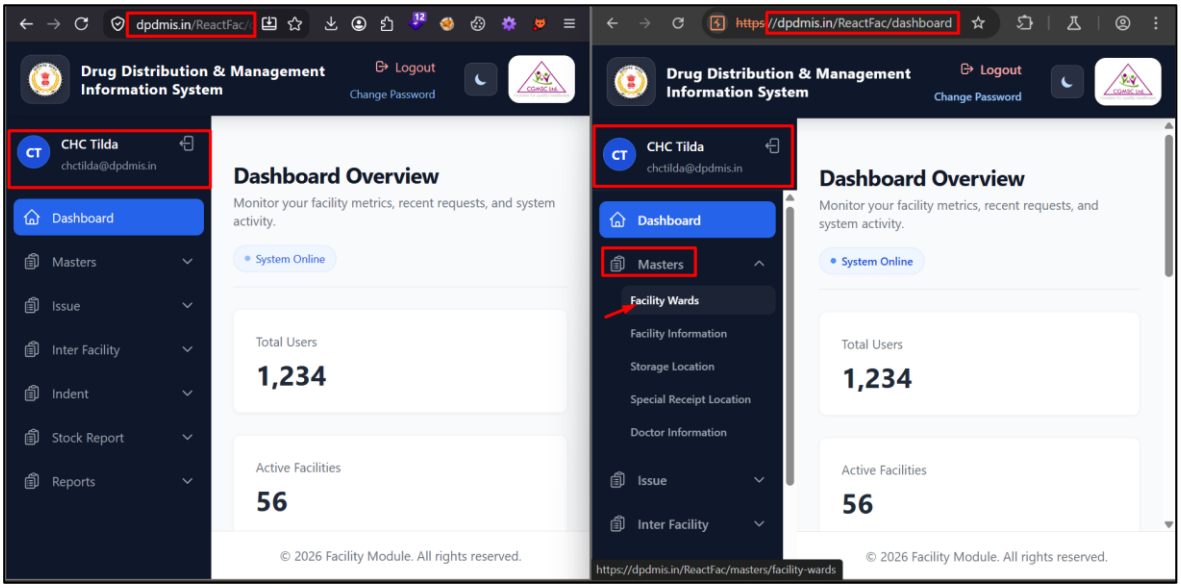
POC 1 - Logged into the application from two different browsers using the same user credentials and confirmed that both sessions remained active simultaneously.



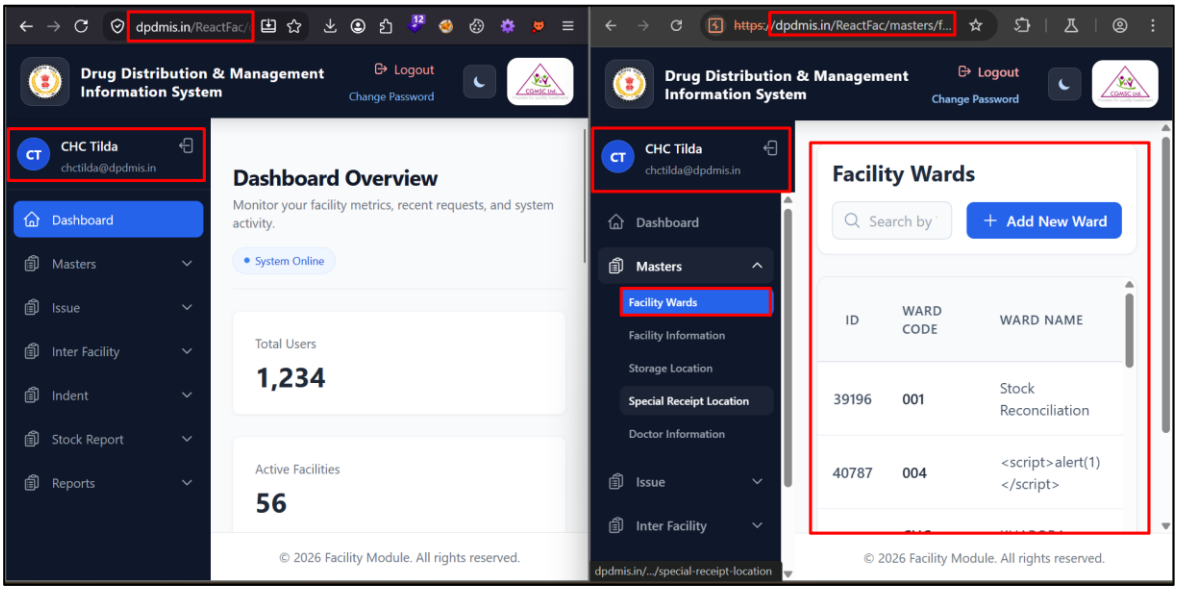
POC 2 - Changed the account password from one browser by providing the current password, new password and confirming the new password.



POC 3 - Changed the account password and intercepted the server response, which returned a success message ("Password changed successfully"), confirming that the password was updated successfully.



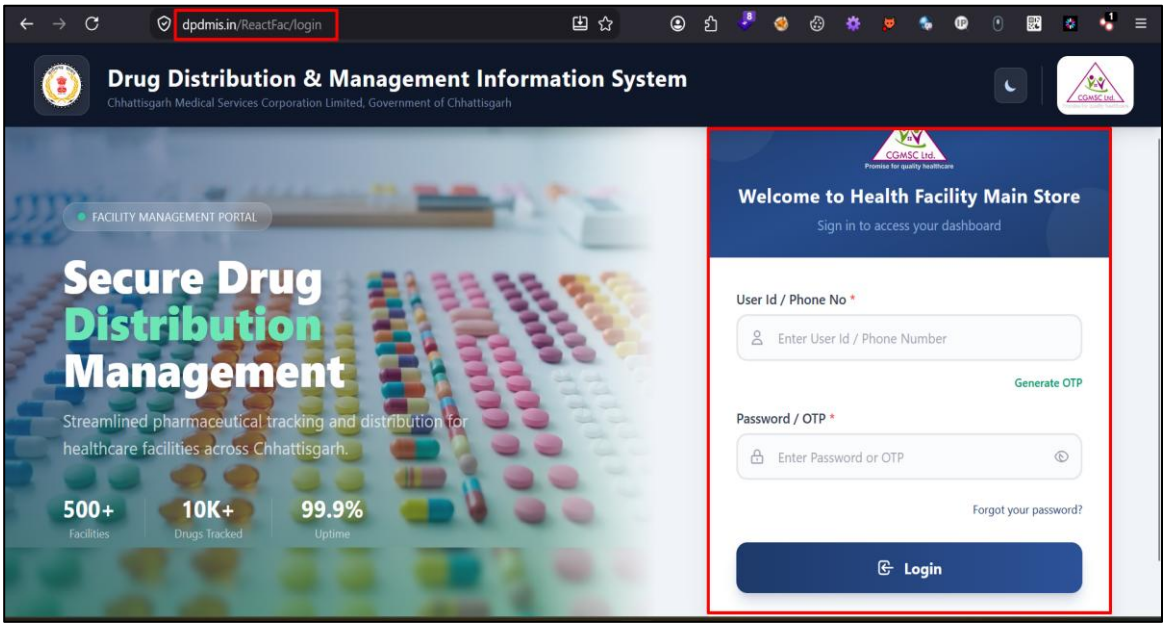
POC 4 - After changing the password in one browser, accessed Masters → Facility Wards from the second browser and confirmed that the existing session remained active without requiring re-authentication.



POC 5 - After the password change, the second browser session remained active and successfully accessed Masters → Facility Wards without requiring re-authentication.

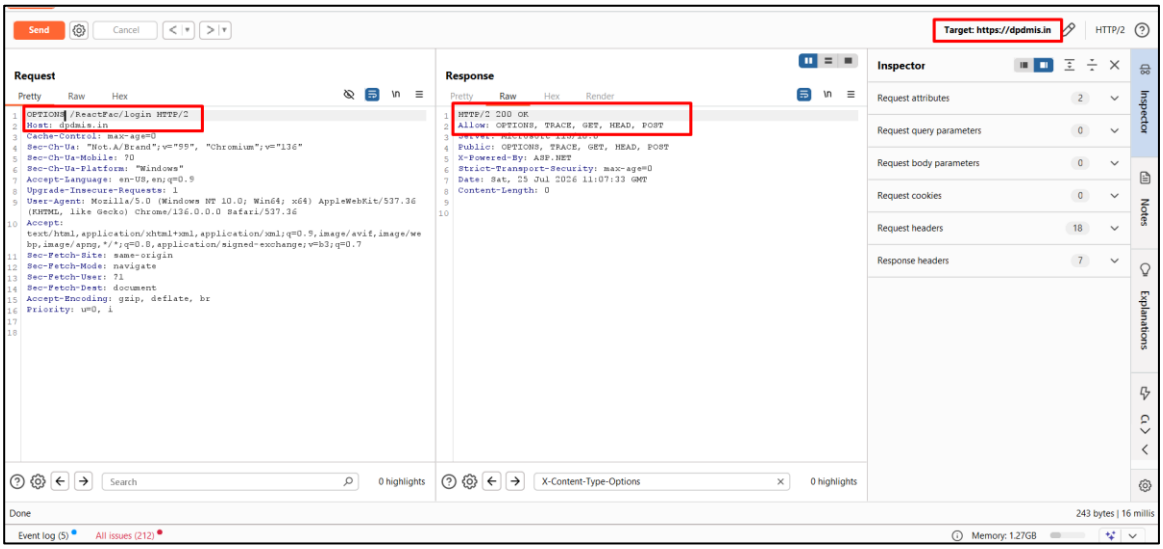
Vulnerability Point No. 20	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login
Vulnerability Name	Multi-Factor Authentication (MFA) missing
CWE/CVE	CWE-308
Severity	Low
Status	Open
Description	The application does not enforce Multi-Factor Authentication (MFA) during user authentication. Although an OTP-based login option is available, users can authenticate successfully using either a username and password or an OTP independently. The application does not require an additional authentication factor after successful password authentication, resulting in single-factor authentication instead of true multi-factor authentication.
Impact	An attacker with a compromised username and password can access the application without any additional verification, increasing the risk of unauthorized access.
Recommendation	Implement Multi-Factor Authentication (MFA) by requiring a second authentication factor after password verification to prevent unauthorized access using compromised credentials.
Proof of Concept	

Note: The below POC shows that Multi-Factor Authentication (MFA) is missing.



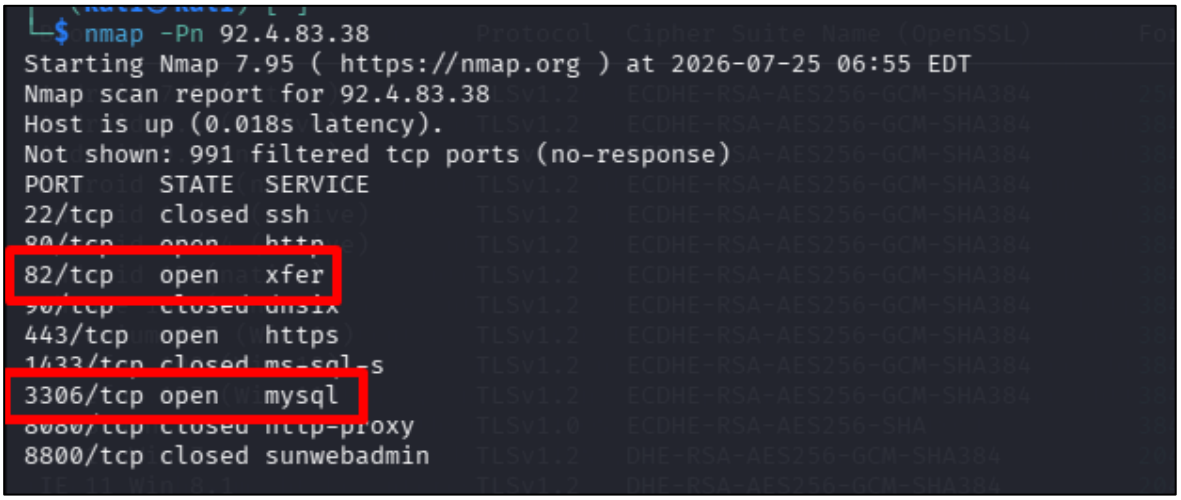
Vulnerability Point No. 21	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login
Vulnerability Name	HTTP OPTIONS method enabled
CWE/CVE	CWE-200
Severity	**Info**
Status	**Open**
Description	The application server responds to HTTP OPTIONS requests. This method reveals supported HTTP methods and can provide information about the server configuration.
Impact	While not directly exploitable, attackers can gather information about allowed HTTP methods and use it to plan further attacks.
Recommendation	Restrict or disable the OPTIONS method unless required. Implement proper server configuration to limit information disclosure.
Proof of Concept	

Note: The below POC shows that HTTP OPTIONS method is enabled, exposing supported methods.



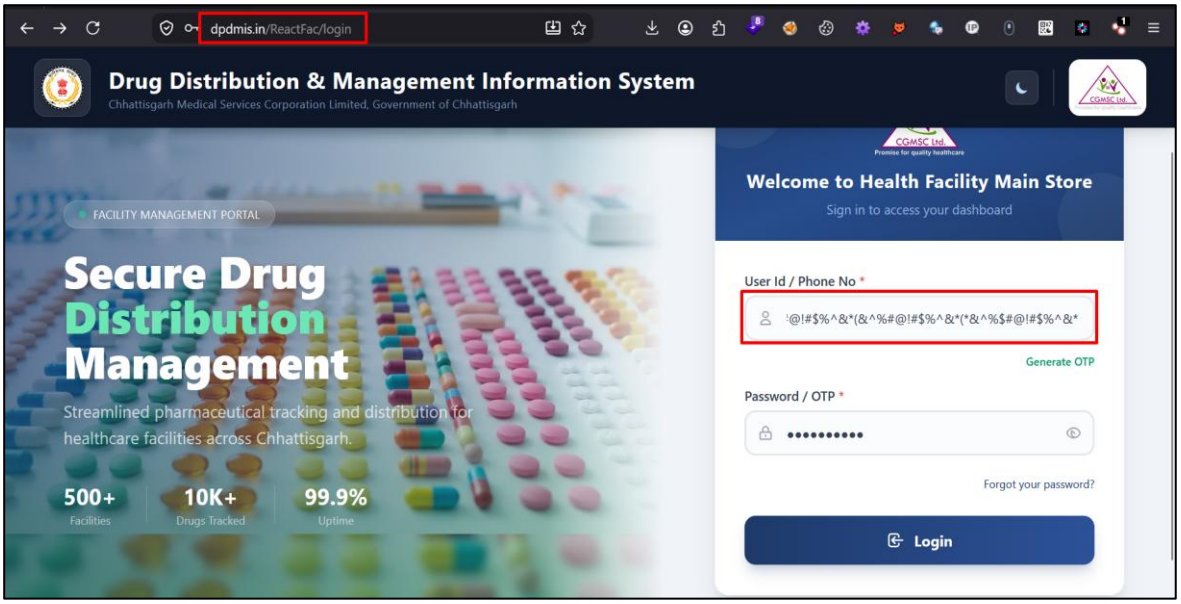
Vulnerability Point No. 22	
Affected URL/ Application/Point / Path	92.4.83.38
Vulnerability Name	Unnecessary open ports
CWE/CVE	CWE-284
Severity	**Info**
Status	**Open**
Description	The server exposes network ports that are not required for application functionality, increasing the attack surface.
Impact	Attackers may exploit services running on open ports to gain unauthorized access, perform reconnaissance, or launch further attacks.
Recommendation	Close all unused ports, restrict access using firewall rules, and allow only required services based on the principle of least privilege.
Proof of Concept	

Note: The below POC shows that unnecessary ports are opened.

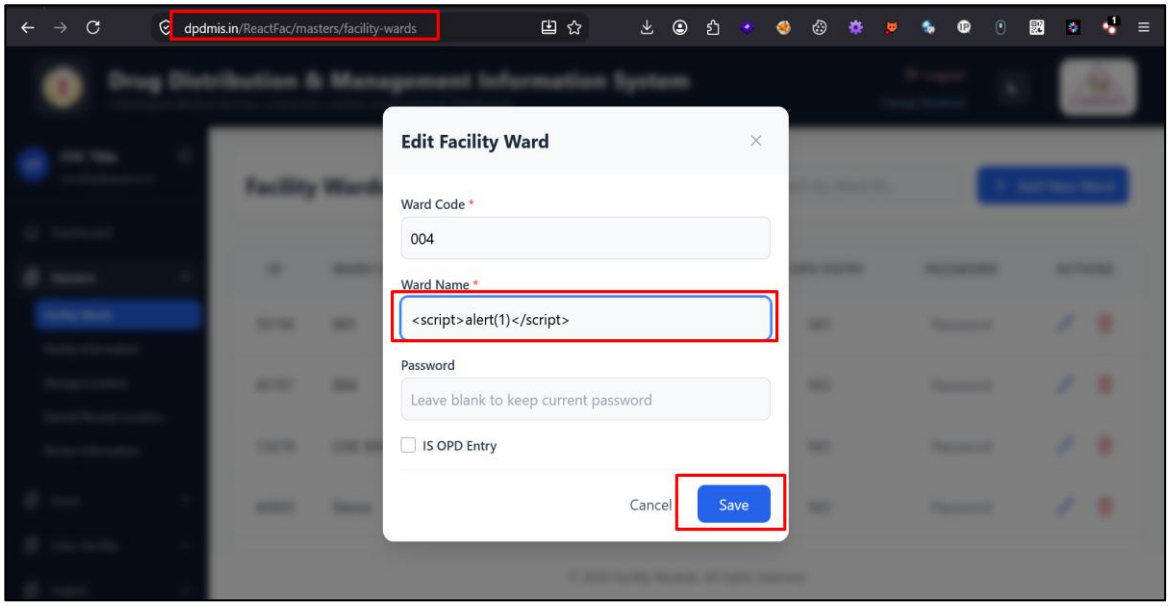


Vulnerability Point No. 23	
Affected URL/ Application/Point / Path	https://dpdmis.in/ReactFac/login https://dpdmis.in/ReactFac/masters/facility-wards https://dpdmis.in/ReactFac/masters/special-receipt-location https://dpdmis.in/ReactFac/masters/doctor-information
Vulnerability Name	Improper input validation
CWE/CVE	CWE-20
Severity	**Info**
Status	**Open**
Description	The application does not validate or sanitize user inputs in certain requests. While no active exploit was observed, improper input validation may allow injection attacks, unexpected behavior, or system errors if not handled correctly.
Impact	Potential for attacks such as XSS, SQL injection, command injection, or other input-based exploits in the future.
Recommendation	Implement proper input validation and sanitization on both client and server sides. Apply whitelisting for acceptable input formats. Use parameterized queries and encoding for user-supplied data.
Proof of Concept	

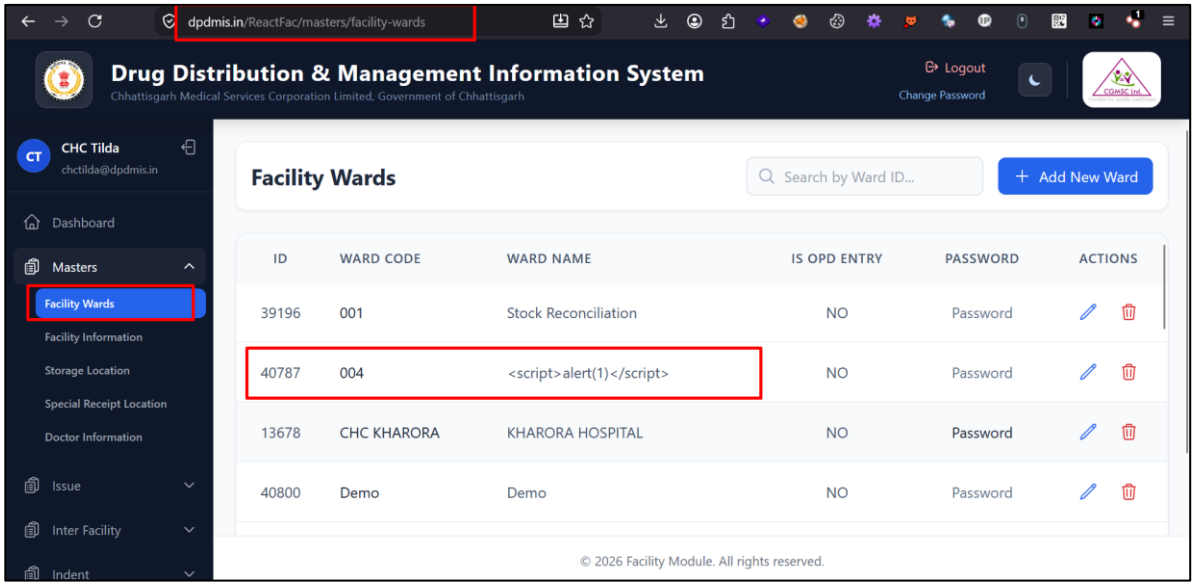
Note: The below POC shows that application is not properly validating user inputs.



POC 1 – The User ID/Phone Number field accepts arbitrary special characters without proper input validation.



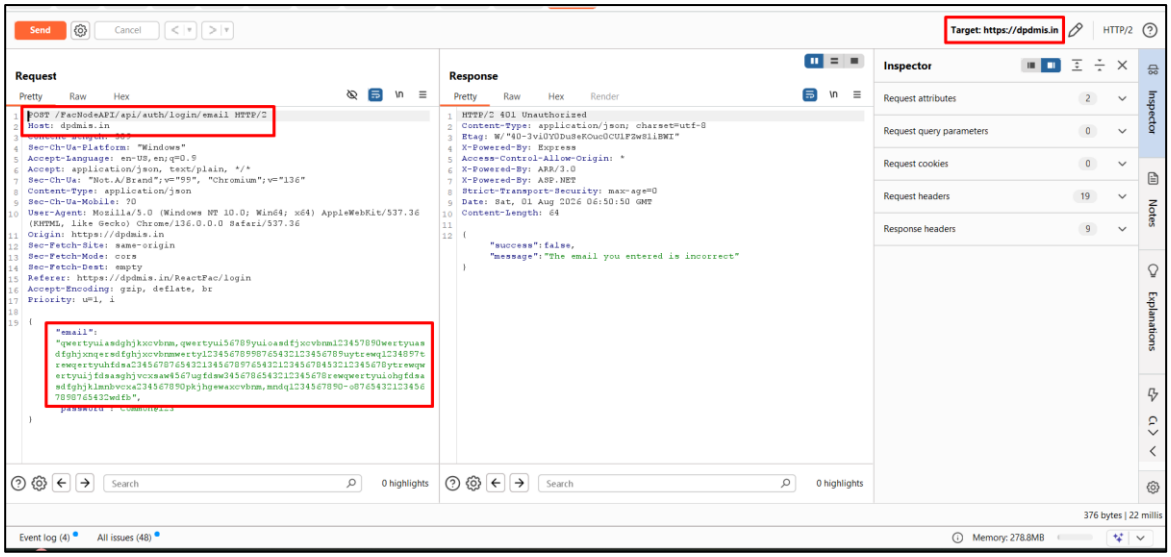
POC 2 - The Create Ward functionality fails to validate user input in the Ward Name field, allowing malicious script payloads to be submitted.



POC 3- The ward was created successfully with the payload <script>alert(1)</script> as the Ward name.

Vulnerability Point No. 24	
Affected URL/ Application/Point / Path	https://dpdmis.in/FacNodeAPI/api/auth/login/email
Vulnerability Name	Potential buffer overflow risk
CWE/CVE	CWE-20
Severity	**Info**
Status	**Open**
Description	The application input fields allow the submission of excessively long characters without enforcing defined maximum length restrictions. Lack of input length validation may expose the application to potential security and stability risks at the backend.
Impact	Allowing very long input values increases the application's exposure to attacks. It can slow down the application, cause unexpected behavior, and may create security issues if the backend does not handle large inputs safely.
Recommendation	Set a fixed maximum length for all input fields on the server side. Reject inputs that exceed this limit and ensure all user inputs are safely processed to prevent misuse.
Proof of Concept	

Note: Below POC shows that input fields accept long inputs.



********** **End of the report** **********